

UF8

Legislación

Ciberseguridad

ÍNDICE

Introducción.....	04
Objetivos.....	05
Mapa conceptual	06
1. Normativa y regulaciones sobre seguridad y protección de datos.....	07
1.1. El delito informático.....	08
A. Estructura del Código Penal de 1995	08
B. El aspecto social de la informática	09
C. Actualización a la normativa vigente.....	09
1.2. El Código Penal y las conductas ilegales asociadas	
a la informática	10
A. Delitos contra la intimidad personal	10
B. Delito de estafa informática	12
C. Delito por uso indebido de equipamientos	14
D. Delitos de daños informáticos.....	14
1.3. Propiedad intelectual y redes P2P: marco legal y sanciones.....	16
A. Redes peer-to-peer (P2P)	16
B. Ley de Propiedad Intelectual.....	16
C. Licencias de software.....	17
1.4. Delito de divulgación de secretos empresariales	19
1.5. Delito de fraude económico a los prestadores de servicios.....	20
1.6. Otros tipos de delitos y la metodología de investigación.....	20
2. Estrategias de mantenimiento y gestión de la seguridad.....	25
2.1. Normativa legal sobre protección de datos personales	25
A. Agencias autonómicas de protección de datos	25

B. Evolución de la legislación sobre protección de datos.....	26
C. Reglamento general de protección de datos	27
D. Definición de datos personales.....	27
E. Condiciones para el tratamiento y la transferencia internacional de datos personales según el RGPD	29
F. Consentimiento y transparencia en el tratamiento de datos personales según el RGPD.....	30
G. Derechos de los interesados en el tratamiento de datos personales según el RGPD	31
2.2. Sistemas de seguridad para el acceso a datos personales almacenados	35
A. Autenticación	36
B. Protección de datos mediante criptografía	39
2.3. Legislación sobre los servicios de la sociedad de la información, comercio electrónico, correo electrónico y firma electrónica	40
A. Servicios de la sociedad de la información	40
B. Normas y responsabilidades de las empresas que prestan servicios por Internet	41
C. Normas sobre el envío de publicidad no deseada (spam)	42
D. Legislación sobre la firma electrónica.....	42
2.4. Configuración de programas cliente de correo electrónico para el cumplimiento de normas sobre gestión de seguridad de la información	43
A. Normativa aplicable al correo electrónico	44
B. Configuración de programas cliente de correo para garantizar la privacidad.....	45
C. Herramientas	46
Solucionario casos prácticos	48
Enlaces de interés	51
Glosario.....	52
Bibliografía.....	57

Introducción

En un mundo cada vez más digital, las leyes que protegen la seguridad informática y los datos personales son fundamentales. Por ello, además de los conocimientos técnicos que ya has adquirido, debes comprender la normativa clave que regula las conductas dentro del ámbito de la ciberseguridad. Conocerla te convertirá en un profesional indispensable en el entorno digital.

Por ejemplo, ¿tienes claro qué constituye un delito informático? Este concepto abarca desde el acceso no autorizado a sistemas hasta la difusión de malware. Te pedirán que informes sobre las repercusiones legales de estos delitos, con sanciones que pueden afectar tanto a individuos como a organizaciones. Saber prevenir estos delitos y gestionar las consecuencias que se derivan de ellos es esencial para proteger la integridad de los sistemas de tu compañía.

La protección de los datos personales es clave en cualquier entorno digital. ¿Quieres conocer el reglamento general de protección de datos, las obligaciones que impone a las empresas y los derechos que otorga a los usuarios? Serás capaz de aplicar medidas de seguridad para cumplir con estas normas y evitar sanciones, protegiendo así la privacidad de los individuos. También estarás preparado para abordar los retos legales en la ciberseguridad de cualquier organización, asegurándote de que en aquella en la que trabajes se garantizan la protección de datos y el cumplimiento normativo.

Objetivos

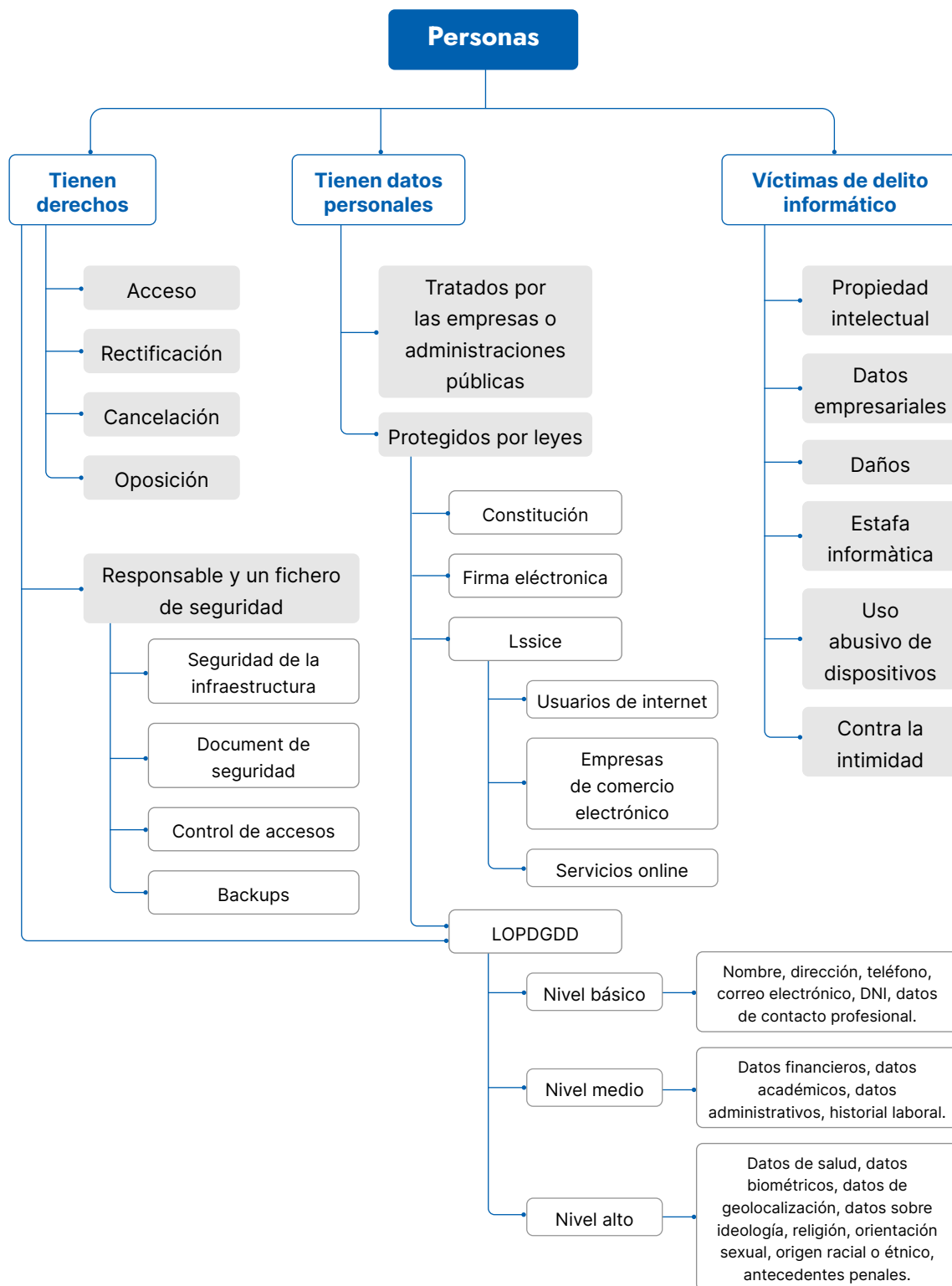
X

Conocer la normativa vigente sobre delitos informáticos y su relación con la tecnología y comprender la importancia de la privacidad y la protección de los datos personales.

X

Identificar los tipos de delitos informáticos y las conductas ilegales asociadas a la informática y reflexionar sobre el cumplimiento de la ley y la ética profesional en el ámbito de la seguridad informática.

Mapa conceptual



01 Normativa y regulaciones sobre seguridad y protección de datos

Aunque sea de forma intuitiva, todo el mundo conoce la existencia de un conjunto de normas jurídicas que regulan las conductas constitutivas de delito, así como las sanciones previstas en estas situaciones (que pueden ser incluso privativas de libertad). El compendio legislativo aplicable en este tipo de materia se denomina Código Penal. Cada país dispone de sus propias normas y, por tanto, es posible que varíen de un país a otro.

DEFINICIÓN

El **delito** es un concepto central en este ámbito. Se define como una conducta **típica** (es decir, tipificada o descrita por la ley como delictiva), **antijurídica** (contraria a derecho), **culpable** (imputable a una persona con capacidad de entender y querer) y **punible** (sancionable con una pena). En otras palabras, un delito implica una conducta infractora del derecho penal, ya sea por una **acción** (hacer algo prohibido) o una **omisión** (no hacer algo requerido), siempre que esté tipificada y penada por la ley.

Es muy importante conocer la **esencia** de la normativa que afecta a los equipos informáticos, ya que, independientemente de nuestra voluntad, condiciona el uso de las tecnologías, desde el punto de vista tanto del trabajador técnico como del usuario de un ordenador en cualquier hogar. Nos podemos encontrar con **límites** técnicos y legales; para poner un ejemplo, el límite de velocidad de un coche no está impuesto por límites técnicos, sino por normas legales. De hecho, existen limitadores para evitar que la tecnología pueda superar el límite fijado por la legislación.

1.1. El delito informático



¿SABÍAS QUE...?

Aunque parezca increíble, el Código Penal vigente actualmente en España data del año 1995. En esta norma no aparece el delito informático definido explícitamente, ni tampoco en las reformas posteriores, como la **Ley 15/2003**. Por lo tanto, no podemos hablar de un «delito informático» propiamente dicho, sino de **delitos cometidos con la ayuda de las nuevas tecnologías**, en los que el ordenador se usa como **medio de ejecución del delito** (por ejemplo, el envío de un email con amenazas) o como **objetivo de la actividad delictiva** (por ejemplo, una intrusión en un sistema informático).

La legislación actual presenta **lagunas** en lo que respecta a los mal llamados «delitos informáticos». Por ello, solo podemos ofrecer una serie de **directrices básicas**, más relacionadas con el sentido común que con la normativa compleja que se va generando en torno a la aplicación de las nuevas tecnologías.

DEFINICIÓN

Una **intrusión** consiste en un **acceso no autorizado** a un sistema informático.

A. Estructura del Código Penal de 1995

El **Código Penal de 1995** se divide, a grandes rasgos, en un **título preliminar** y **tres libros**. Contiene **639 artículos**, que recogen todas las conductas susceptibles de ser sancionadas por el Código Penal. Aunque este texto no define explícitamente los delitos informáticos, algunas de sus disposiciones son aplicables a conductas relacionadas con el uso indebido de las tecnologías, como el **acceso ilegal a sistemas informáticos** (artículo 197 bis) o la **difusión de malware** (artículo 264 ter).

B. El aspecto social de la informática

El enfoque tecnológico o científico de los estudios de informática a menudo deja de lado el **aspecto social** de la aplicación de los avances en estas disciplinas. Como consecuencia, los usuarios y técnicos de sistemas informáticos pueden ser muy competentes en su trabajo, pero es probable que tengan dudas a la hora de abordar problemas como los siguientes:

- » Si mi jefe me pide que le muestre el contenido del correo personal de un trabajador, ¿tengo la obligación de hacerlo?
- » ¿Puedo acceder a la bandeja de correo electrónico de un amigo sin su permiso?
- » Unos intrusos han modificado la página web de la empresa en la que trabajo. ¿Es denunciable este hecho? ¿Ante quién debo denunciarlo?
- » El sistema informático de mi trabajo almacena datos de carácter personal (como nombres, apellidos, direcciones y DNI de los trabajadores). ¿Es necesario proteger estos datos con medidas de seguridad específicas?
- » ¿Puedo subir a Internet una página web con fotografías y logotipos de mi grupo de música favorito?
- » ¿Puedo descargar libremente cualquier archivo de música de Internet?

Es probable que ninguno de estos ejemplos represente una gran dificultad técnica. Sin embargo, es importante tener en cuenta que, aunque no todas estas acciones sean constitutivas de delito, **todas pueden tener consecuencias importantes**. Por lo tanto, hay que ser consciente de que no existe una línea de actuación única y que es necesario ser prudente al tratar este tipo de problemas. No todo lo que es técnicamente posible es legal, y, sobre todo, se tiene que recordar que **el desconocimiento de las normas no exime de responsabilidad** (penal o de otro tipo) al profesional de la informática.

C. Actualización a la normativa vigente

A pesar de que el Código Penal de 1995 no define explícitamente los delitos informáticos, las reformas posteriores, como la **Ley Orgánica 5/2010**, han incorporado actualizaciones, como la inclusión de nuevos delitos relacionados con el uso indebido de la tecnología:

- » **Artículo 197 bis:** castiga el acceso no autorizado a sistemas informáticos y la interceptación de comunicaciones.
- » **Artículo 264 ter:** penaliza la creación y distribución de malware.
- » **Artículo 278:** castiga la propagación de materiales ilícitos a través de medios digitales.

- » Además, la **Ley Orgánica de Protección de Datos Personales y Garantía de los Derechos Digitales (LOPDPGDD)** y el **Reglamento General de Protección de Datos (RGPD)** establecen normas específicas para la protección de datos personales, lo que incluye medidas de seguridad obligatorias y cada día más restrictivas para sistemas que almacenen este tipo de información.

En conclusión, como acabamos de comentar, el delito informático no está explícitamente definido en el Código Penal, pero la legislación española se ha ido adaptando a trancas y barrancas para cubrir los ciberdelitos, que por desgracia son cada día más comunes.

1.2. El Código Penal y las conductas ilegales asociadas a la informática

El Código Penal español es muy estricto en la protección de los derechos fundamentales y las libertades públicas, que se recogen en el **Título I de la Constitución**. Estos derechos y libertades son esenciales a la condición humana y, por ello, gozan de una protección especial.

La Constitución de 1978 es la norma suprema del Estado, por encima de cualquier otra ley o norma. Uno de los artículos más relevantes para el ámbito de la informática (tanto para profesionales como para usuarios) es el 18, que reconoce el derecho a la intimidad. Este derecho protege no solo la vida privada del individuo, sino también su ámbito familiar.

A. Delitos contra la intimidad personal

Una gran parte de los delitos informáticos se pueden tipificar o clasificar dentro de los delitos contra la intimidad. Normalmente, los responsables de estas conductas no son conscientes de que no todo es legal y que la ley salvaguarda determinados bienes. El problema procede de que no se dan cuenta de las consecuencias de sus acciones hasta que es tarde.

Estos delitos están recogidos en el **artículo 197.1** del actual Código Penal, que establece que las siguientes conductas son constitutivas de delito:

- » El apoderamiento de papeles, cartas, mensajes de correo electrónico o cualquier otro documento o efectos personales.
- » La interceptación de las telecomunicaciones.
- » La utilización de artificios técnicos de escucha, transmisión, grabación o reproducción de sonido, o de cualquier otra señal de comunicación.

Para que estas actividades sean constitutivas de delito, deben realizarse **sin el consentimiento de la persona afectada** (ni autorización judicial motivada o justificada) y con la intención de descubrir secretos o vulnerar la intimidad.

Por lo tanto, abrir el email de otra persona y leer los mensajes que hay podría constituir un delito. Es importante tener mucho cuidado con este tipo de acciones (técnicamente suelen ser muy sencillas de realizar, pero no por ello son legales) y, como norma general, **nunca se debe leer ningún email que no esté dirigido a uno mismo** (ni siquiera si un superior en el ámbito laboral lo solicita).

En el caso de la interceptación del correo electrónico dentro del ámbito empresarial, suele argumentarse que los trabajadores no pueden utilizar los medios de la empresa para asuntos personales. Hay **jurisprudencia a favor de las empresas**, ya que se entiende que los medios pertenecen a la organización en sí y, por tanto, no son adecuados para enviar y recibir mensajes de carácter privado. Sin embargo, ante la duda, siempre hay que tener presente que los correos de los trabajadores de una empresa gozan de la misma protección legal en cuanto a la intimidad que los correos electrónicos personales.

» **Actividades personales:** estas actividades personales pueden ser tan simples como el uso de los juegos que vienen instalados en los sistemas operativos. Una forma útil de informar a los usuarios de una organización sobre los usos correctos de los medios de la empresa y sus limitaciones es mediante contratos en los que se especifiquen, por ejemplo, las obligaciones y responsabilidades de un usuario de una cuenta de correo corporativo. Si como técnicos se nos requiere demostrar el uso indebido de algún medio electrónico de la organización, siempre será preferible utilizar controles lo menos lesivos posible, como el monitoreo o el seguimiento del número de bytes transmitidos o recibidos por un usuario concreto (si un usuario descarga archivos de vídeo o canciones, el número de bytes recibidos será, probablemente, mucho mayor que si hiciera un uso normal del correo).

» **Usurpación y cesión de datos reservados de carácter personal:** los artículos 197, 198, 199 y 200 del Código Penal (CP) tipifican como conductas delictivas el acceso, la utilización, la modificación, la revelación, la difusión o la cesión de datos reservados de carácter personal que se encuentren almacenados en archivos, soportes informáticos, electrónicos o telemáticos, siempre que estas conductas las realicen personas no autorizadas (conductas denominadas, genéricamente, abusos informáticos sobre datos personales). Además de la responsabilidad penal en la que pueden derivar este tipo de acciones, también hay que considerar que los datos personales deben almacenarse y declararse según una normativa especificada en la **Ley Orgánica de Protección de Datos Personales y Garantías de los Derechos Digitales (LOPDGDD)**. En cuanto al Código Penal, se menciona explícitamente el agravante de estas conductas cuando los datos objeto del delito son de carácter personal y revelan cuestiones de ideología, religión, creencias,

salud, origen racial o vida sexual. Otros agravantes que tener en cuenta se producen cuando la víctima es un menor de edad o una persona incapacitada, o cuando el autor del delito es el responsable de los archivos involucrados. Merece una consideración especial el artículo 199.2, que castiga la conducta del profesional que, incumpliendo la obligación de reserva, divulga los secretos de otra persona.



¿SABÍAS QUE...?

A los efectos de este código, según el artículo 25, se considera **incapaz** a toda persona, se haya declarado o no su incapacitación, que padezca una enfermedad de carácter persistente que le impida gobernar su persona o bienes por sí misma.

En definitiva, el sentido común ya nos advierte que estas acciones pueden tener algún tipo de repercusión. Lo que probablemente desconocemos es que puedan derivar en **responsabilidades penales**. Así, como técnicos y usuarios de sistemas informáticos, es bastante probable que tengamos acceso a datos personales y protegidos, sobre los cuales tenemos la obligación legal de mantenerlos en secreto y no cederlos a nadie.

La **revelación del secreto profesional** es una conducta tipificada en el artículo 199 del Código Penal.

B. Delito de estafa informática

El **artículo 248.2** del Código Penal castiga la conducta de quien, mediante cualquier manipulación informática, consiga la transferencia no consentida de cualquier dato, con ánimo de lucro y perjuicio para un tercero. Además, el CP también tipifica las conductas preparatorias para la comisión de delitos de fraude informático, que pueden incluir la fabricación, la facilitación o la mera posesión de software específicamente diseñado para cometer este tipo de delitos.

Por desgracia, los delitos informáticos cada vez son más frecuentes. A continuación, presentamos algunos de los más importantes:

Phishing y pharming: como ya hemos visto, el **phishing** es una técnica de ingeniería social en la que los ciberdelincuentes suplantan la identidad de entidades legítimas (como bancos o plataformas de pago) para obtener información confidencial de los usuarios, como usuarios y contraseñas. Esto se realiza a través de correos electrónicos falsos o páginas web clonadas. Por otro lado, el **pharming** es una técnica más sofisticada que redirige a los usuarios a sitios web falsos, incluso cuando introducen la dirección correcta

en su navegador (DNS-spoofing). Ambas prácticas están tipificadas como delitos de fraude informático en el artículo 248.2 CP.

Malware y ransomware

El **malware** es software diseñado para dañar sistemas, robar información o tomar el control de dispositivos. Dentro de esta categoría, el **ransomware** es un tipo de malware o ataque de ciberseguridad de suplantación de identidad que destruye o cifra archivos y carpetas en un equipo, servidor o dispositivo. Una vez que los dispositivos o archivos están bloqueados o cifrados, los ciberdelincuentes pueden extorsionar al propietario de la empresa o del dispositivo para exigirle dinero a cambio de una clave que desbloquea los datos cifrados. Sin embargo, incluso cuando se paga, puede que los ciberdelincuentes nunca den la clave al propietario de la empresa o del dispositivo y detengan el acceso permanentemente. Estos delitos se encuadran en el artículo 264 CP, que castiga el sabotaje de datos o sistemas informáticos.

Suplantación de identidad

También conocida como **spoofing**, consiste en hacerse pasar por otra persona o entidad para cometer fraudes o acceder a información confidencial. Este delito se regula en el artículo 401 CP y puede incluir la creación de perfiles falsos en redes sociales o el uso de correos electrónicos fraudulentos.

Criptojacking

Es cuando se utilizan recursos informáticos de una víctima (como su ordenador o servidor) para minar criptomonedas sin su consentimiento. Este delito se considera un acceso ilícito a sistemas informáticos, según el artículo 197 CP.

Ataques de Denegación de Servicio (DDoS)

Tienen como objetivo inhabilitar el uso de un sistema, una aplicación o una máquina, con el fin de bloquear el servicio para el que está destinado. Este ataque puede afectar tanto a la fuente que ofrece la información, como puede ser una aplicación o el canal de transmisión, como a la red informática. Los servidores web poseen la capacidad de resolver un número determinado de peticiones o conexiones de usuarios de forma simultánea; en caso de superar ese número, el servidor comienza a ralentizarse e incluso puede llegar a no ofrecer respuesta a las peticiones o a bloquearse directamente y desconectarse de la red. Estos ataques están tipificados en el artículo 264.2 CP.

Clonación de tarjetas y skimming

La clonación de tarjetas de crédito o débito mediante dispositivos **skimming** (instalados en cajeros automáticos o terminales de pago) es un delito grave que se asimila a la falsificación de moneda, según el artículo 387 CP. Los delincuentes copian la información de la banda magnética para realizar transacciones fraudulentas.

Pornografía infantil y grooming

La distribución, posesión o producción de pornografía infantil a través de medios informáticos está tipificada en el artículo 189 CP. Además, el **grooming**, que consiste en el acoso sexual a menores a través de Internet, está castigado con penas de prisión en el artículo 183 ter CP.

Ciberacoso y stalking

El **ciberacoso** (acoso a través de medios digitales) y el **stalking** (persecución o vigilancia obsesiva) son delitos que afectan gravemente a la privacidad y la integridad emocional de las víctimas. Estos comportamientos están regulados en los artículos 172 ter y 173 CP.

Falsificación documental

La creación o modificación de documentos digitales con fines fraudulentos se considera falsificación documental, según el artículo 390 CP. Esto incluye la manipulación de facturas, contratos o certificados.

Espionaje industrial y robo de datos

El acceso no autorizado a sistemas informáticos para robar información confidencial de la empresa está tipificado en el artículo 197 CP. Este delito es especialmente relevante en el ámbito empresarial, donde el espionaje industrial puede causar graves perjuicios económicos.

Ingeniería social

Es una técnica que no depende de un conocimiento técnico importante, sino que se basa en el intento de manipular psicológicamente a las víctimas. Se utilizan tácticas como el pretexting (crear una situación falsa para obtener información) o el baiting (ofrecer algo atractivo para incitar a la víctima a actuar). Estas prácticas están asociadas a delitos como el phishing o la suplantación de identidad.

C. Delito por uso indebido de equipamientos

El **artículo 256 CP** castiga el uso de cualquier equipo terminal de telecomunicaciones sin el consentimiento del titular, siempre que esto le ocasione un perjuicio superior a 400 €. Esta cantidad fue establecida por la Ley 15/2003.

Por ejemplo, el uso indebido o no consentido de una conexión wifi podría incluirse dentro del artículo 256. Sin embargo, primero sería necesario acreditar el perjuicio económico que se haya podido causar.

D. Delitos de daños informáticos

Los delitos de daños, junto con los delitos contra la intimidad y contra la propiedad intelectual, son, con diferencia, los más frecuentes. De manera similar a lo que sucede con los delitos contra la intimidad, muchas veces los autores de estas acciones no son conscientes de las consecuencias que pueden acarrear.

Según el **artículo 264**, el delito de daños consiste en la destrucción, alteración, inutilización o cualquier otra modalidad que implique el daño de datos, software o documentos almacenados en la nube, soportes o sistemas informáticos.

Como es fácil imaginar, este delito puede tener repercusiones económicas importantes para las organizaciones afectadas. En consecuencia, las sanciones por estas acciones pueden implicar multas importantes.

Los daños producidos en un sistema informático deben poder cuantificarse, y es esencial adjuntar una valoración en el momento de presentar una denuncia a la policía. La valoración de los daños es un proceso complejo que puede abarcar diferentes aspectos: coste de restauración de una página web y pérdidas por publicidad no emitida (lucro cesante) o por servicios que no se han podido prestar, entre otros.

EJEMPLO

La **alteración de una página web** por una persona no autorizada es un caso típico de delito de daños. Aunque en algunos casos pueda parecer una acción inocente (e incluso divertida, en el ámbito de los atacantes informáticos), puede causar pérdidas muy cuantiosas.

Un cracker es una persona que realiza ataques a sistemas informáticos con fines destructivos. Es importante decir que, si bien la intrusión en un sistema informático por sí misma no constituye actualmente un delito (aunque pronto tendrá esta consideración), este tipo de acciones suelen estar vinculadas a otras conductas que sí lo son, como los delitos contra la intimidad, los daños en un sistema informático o los medios utilizados para llevar a cabo el acceso no autorizado (por ejemplo, el sniffing de contraseñas).

El **envío de un virus** (con intención de causar daños), entre otros casos similares, también podría considerarse un delito de daños. Sin embargo, es importante tener en cuenta que la cantidad de **400 €** marca la diferencia entre una falta y un delito.

Por desgracia, en la actualidad, los delitos relacionados con el uso no autorizado de redes wifi y los daños informáticos han aumentado considerablemente. Con el alza del teletrabajo y la dependencia de sistemas en línea, las organizaciones son más vulnerables a este tipo de ataques. Además, como siempre, las legislaciones van tarde, y están empezando a adaptarse a estas nuevas infracciones, endureciendo las sanciones y ampliando la tipificación de los delitos informáticos.

Por ejemplo, la **Ley Orgánica 1/2015** introdujo modificaciones en el Código Penal para incluir delitos como la difusión no consentida de datos personales o el acceso ilícito a sistemas informáticos, incluso cuando no se cause un daño económico directo.

1.3. Propiedad intelectual y redes P2P: marco legal y sanciones

El delito contra la propiedad intelectual siempre genera controversia, ya que está muy vinculado con la descarga de archivos protegidos por derechos de autor y el intercambio de estos a través de redes peer-to-peer (P2P). A esto se suma la irrupción rapidísima de la **inteligencia artificial (IA)**, que ha añadido más complejidad al debate, ya que plantea desafíos inexplorados en la protección de los derechos de autor y la propiedad intelectual en entornos digitales. La combinación de nuevas tecnologías con el intercambio de archivos está generando un escenario en el que los límites legales y éticos se vuelven cada vez más inciertos, requiriendo una constante actualización de la normativa y un esfuerzo mayor por parte de las administraciones para garantizar los derechos de los autores en un mundo que evoluciona de una forma muy rápida.

A. Redes peer-to-peer (P2P)

En este tipo de redes, cada nodo puede actuar de servidor y cliente a la vez. Al ser redes descentralizadas, son adecuadas para compartir archivos entre los usuarios que las integran, cuyos contenidos pueden estar protegidos, o no, por las leyes de propiedad intelectual. El software P2P más conocido es **eMule**, basado en la red **eDonkey**.

B. Ley de Propiedad Intelectual

En el marco jurídico no penal, la **Ley de Propiedad Intelectual** regula la protección de obras literarias, artísticas y científicas. Según el **artículo 270 del Código Penal (CP)**, las conductas relacionadas con los delitos contra la propiedad intelectual incluyen la reproducción, el plagio, la distribución o la comunicación pública, total o parcial, de una obra literaria, artística o científica sin la autorización de los titulares de los derechos de propiedad intelectual.

Estas condiciones se aplican independientemente del soporte en el que se haya registrado la obra (textos, software, vídeos, sonidos, gráficos, etc.). Es decir, la venta, distribución o fabricación de copias no autorizadas de software constituye un delito contra la propiedad intelectual. Sin embargo, según la interpretación literal del Código Penal, estas acciones deben haberse realizado con ánimo de lucro y en perjuicio de terceros. Por lo tanto, para aplicar este artículo, es esencial demostrar la existencia de este beneficio.

No podemos hacer un uso libre de la información disponible en Internet (gráficos, logos, fotos, etc.) sin el permiso de los titulares de los derechos de propiedad intelectual.

EJEMPLO

Las siguientes actuaciones serían constitutivas de delito contra la propiedad intelectual:

- » Reproducción y venta de software sin licencia.
- » Instalación de copias no autorizadas de software en equipos informáticos.
- » Publicación de código fuente o archivos (MP3, libros, etc.) en Internet sin permiso.
- » Uso de una licencia de software para un solo ordenador en una red completa.
- » Elusión de mecanismos de protección de software (cracking).

El **artículo 270 CP** también prevé sanciones para quienes distribuyan o posean herramientas diseñadas específicamente para anular dispositivos técnicos de protección de software, como programas para saltar las protecciones anticopia de los DVD o Blu-ray.

C. Licencias de software

IMPORTANTE

Una **licencia de software** es un contrato entre el autor de los derechos de explotación y el usuario que establece las condiciones de uso del software.

Aunque algunos países de la Unión Europea han intentado regular la descarga y el intercambio de contenidos protegidos mediante programas P2P, aún no se ha alcanzado un consenso. Sin embargo, es importante aclarar que la instalación y el uso de programas P2P no es ilegal, siempre que se utilicen de manera lícita.

Actualmente, está permitido realizar copias privadas de obras literarias, artísticas o científicas sin autorización previa, siempre que se haya accedido legalmente a la obra y la copia no se utilice con fines colectivos, lucrativos o para perjudicar a terceros. No obstante, este derecho no es aplicable al software (incluyendo videojuegos).

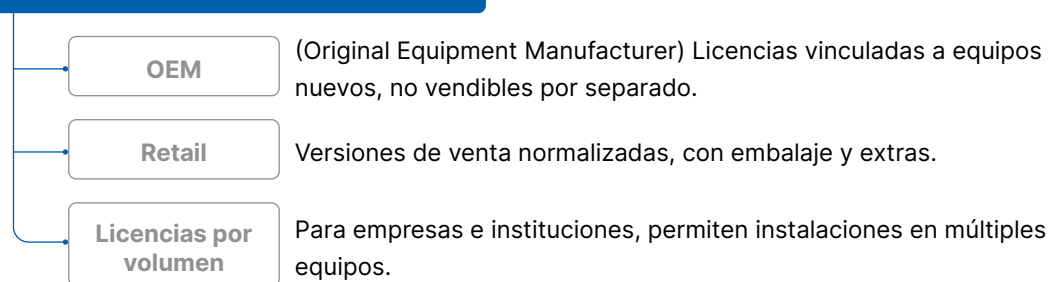
DEFINICIÓN

El **canon por copia privada** o **canon digital** es una tasa aplicada a diversos medios de grabación y cuya recaudación reciben los autores, editores, productores y artistas asociados a alguna entidad privada de gestión de derechos de autor, en compensación por las copias que se hacen de sus trabajos en el ámbito privado.

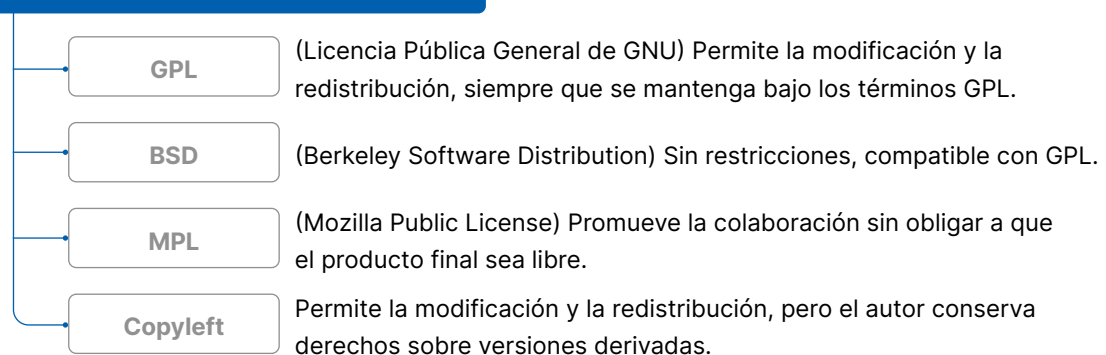
El canon por copia privada se cobra en España a los **fabricantes e importadores de los equipos, aparatos y materiales que sirven para la duplicación de obras** protegidas por la Ley de Propiedad Intelectual y disposiciones conexas, ya sean literarias, musicales o audiovisuales. No obstante, la Sociedad General de Autores y Editores (SGAE) indica que la Ley de Propiedad Intelectual considera responsables solidarios del pago de la remuneración a los distribuidores, mayoristas y minoristas sucesivos adquirentes, si en la factura de sus proveedores no aparece desglosado el importe de la remuneración.

Estos son los tipos de licencias:

Licencias de software no libre



Licencias de software libre



1.4. Delito de divulgación de secretos empresariales

Según el artículo 278.1 del Código Penal, comete revelación de secretos empresariales quien, con la finalidad de obtener información, intercepte cualquier comunicación o utilice dispositivos de escucha, transmisión, grabación o registro de sonido, imagen o cualquier otra conexión.

DEFINICIÓN

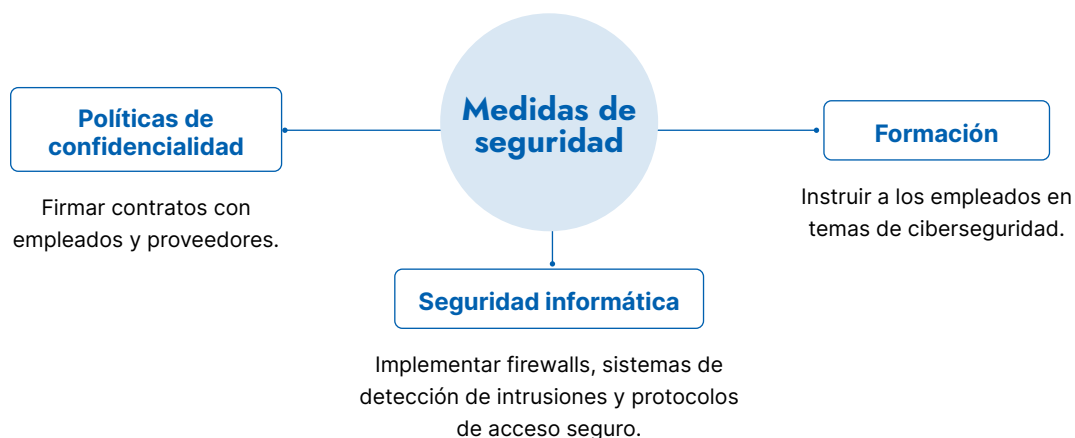
Un típico ejemplo sería el **espionaje industrial**, que puede definirse como la obtención no autorizada de información confidencial de una empresa (fórmulas, procesos, estrategias comerciales, datos de clientes, etc.) con el fin de obtener una ventaja competitiva o perjudicar a una empresa específica. Con las tecnologías actuales, el espionaje industrial ha evolucionado y alcanzado un alto grado de sofisticación. Las empresas están obligadas a proteger sus datos, y lo pueden hacer utilizando criptografía para cifrarlos, monitorizando las redes y formando a los empleados en temas de ciberseguridad. Además, la legislación española, siguiendo la Directiva (UE) 2016/943 sobre la protección de los secretos comerciales, castiga duramente este tipo de delitos.

El artículo 278.1 forma parte de los delitos contra el mercado y los consumidores. Su función es proteger la competitividad empresarial y la innovación. Las penas por este delito pueden incluir multas importantes e incluso prisión, dependiendo de la gravedad de la infracción y del daño causado a la empresa afectada.

EJEMPLO

Estos son algunos ejemplos de conductas que pueden constituir revelación de secretos de empresa:

- » **Interceptación de comunicaciones:** acceder a emails, mensajes o llamadas telefónicas de empleados de una empresa para obtener información confidencial.
- » **Uso de software espía:** instalar malware en los sistemas informáticos de una empresa para robar datos sensibles.
- » **Acceso no autorizado a sistemas:** hackear los servidores de una empresa para extraer información protegida.
- » **Grabaciones ilegales:** grabar conversaciones o reuniones internas sin consentimiento para obtener información privilegiada.



1.5. Delito de fraude económico a los prestadores de servicios

El delito de fraude de los intereses económicos de los prestadores de servicios es un nuevo delito que aparece en el **artículo 286**, introducido a raíz de la reforma 15/2003 del Código Penal.

Castiga a quien facilite a terceros el acceso a servicios interactivos o audiovisuales (como, por ejemplo, las plataformas de streaming como Netflix, HBO, Disney Channel...) sin el permiso de los prestadores de estos servicios. De hecho, la simple explicación, por ejemplo, en una página web de Internet, sobre cómo se pueden evitar o «saltar» los mecanismos de protección de cualquier tipo de sistema (para activar por ejemplo un software de pago) es ya considerada una actividad delictiva.

1.6. Otros tipos de delitos y la metodología de investigación

Además de los delitos descritos en los anteriores apartados, hay con total seguridad muchos más que han automatizado y amplificado sus efectos gracias a la tecnología. En estos casos, la innovación reside en el medio de transmisión del delito, el cual ya está tipificado entre los delitos ocurridos en el mundo «real»:

- » **Amenazas y coacciones** (a través de chats o emails).
- » **Falsedad documental** (alteraciones y simulaciones de documentos públicos o privados).
- » **Difusión de pornografía infantil en Internet** (la posesión también es delito).

Los investigadores de delitos informáticos (ya sean policiales o de empresas especializadas) disponen, a grandes rasgos, de dos fuentes de información esenciales:

- » **Los archivos o registros (logs) locales:** los sistemas operativos y las aplicaciones instaladas registran las actividades que se realizan en los archivos de registro. Por ejemplo, la intrusión de un hacker en un sistema informático dejaría, si el atacante no limpia las huellas, un rastro en varios archivos del sistema. La información que contienen estos archivos (por ejemplo, la dirección IP del atacante) es la primera pista que los investigadores analizarían para establecer el origen del ataque o el hecho investigado.
- » **Los registros (logs) de los proveedores de servicio de Internet (ISP):** la persona que ha cometido cualquier hecho susceptible de ser investigado, primero habrá utilizado una conexión a Internet ofrecida por un proveedor (Movistar, Orange, Vodafone, Digi o cualquier otro). Los datos asociados a esta conexión son almacenados obligatoriamente, tal y como marca la Ley de Servicios de la Sociedad de la Información y del Comercio Electrónico (LSSICE). Esta información solo puede ser cedida a los investigadores mediante una orden judicial. Así, una vez que los analistas han encontrado la información básica del suceso (IP de origen, franja horaria y la fecha en que se ha producido el evento), deberán solicitar al juez una orden judicial para que el PSI les entregue los datos requeridos, para poder continuar el proceso e identificar al usuario que ha utilizado la conexión sospechosa.

DEFINICIÓN

Un proveedor de servicios de Internet (PSI) es una empresa dedicada a conectar a los usuarios (clientes) a la Red. También suele ofrecer, entre otros, servicios de alojamiento web y registro de dominios.

Si el administrador de un sistema informático es **víctima de cualquiera de estos delitos**, o descubre, por ejemplo, que el sistema que administra es utilizado como plataforma de distribución de copias de software no autorizadas o de pornografía infantil, debe denunciarlo inmediatamente en la comisaría de policía más cercana.

Este es el protocolo de actuación:

- 1 Adjuntar los archivos de registro (registros locales del sistema)** relacionados con el delito cometido. Estos archivos deberán reflejar, en caso de que hayan quedado registrados, la IP del atacante, las acciones producidas en el sistema investigado, etc.
- 2 En caso de que se haya producido un delito de daños**, se debe adjuntar una valoración del perjuicio ocasionado.
- 3 Actuar con rapidez** (los proveedores no almacenan indefinidamente los archivos de registro de sus servidores).
- 4 En caso de que esta acción delictiva se haya producido por correo electrónico**, se deben adjuntar las cabeceras completas del correo recibido.
- 5 En caso de que sea necesario**, se debe considerar la posibilidad de duplicar (o clonar) el disco duro del servidor para preservar las pruebas del delito y, a continuación, reinstalar el sistema para evitar que el delito continúe produciéndose. Sin embargo, se debe tener cuidado con esta consideración. Supongamos, por ejemplo, que el administrador de un sistema descubre que el servidor del cual es responsable aloja pornografía infantil. La duplicación del disco duro (con el fin de salvaguardar las pruebas) y la reinstalación posterior de todo el sistema permitirían evitar que el delito (la difusión de pornografía infantil) continuara produciéndose, pero al mismo tiempo podrían dificultar la investigación.



¿SABÍAS QUE...?

Los **usuarios domésticos también pueden ser víctimas de delitos** relacionados con las nuevas tecnologías (contra la intimidad, amenazas, coacciones, suplantaciones de identidad, etc.). Muchas de las aplicaciones mediante las cuales se ejecutan estas acciones pueden almacenar sus propios logs (por ejemplo, conversaciones de chat, cabeceras de correo electrónico), los cuales deberían adjuntarse en caso de denuncia.



VIDEOLAB

Para consultar el siguiente vídeo sobre **Leyes y normas relevantes en seguridad informática**, escanea el código QR o [pulsa aquí](#).

Estudiaremos las principales leyes que regulan la seguridad informática y la protección de datos personales. Veremos cómo el Código Penal español y el RGPD sancionan delitos como el acceso no autorizado, la distribución de malware y el fraude digital. También analizaremos los derechos de los ciudadanos sobre sus datos y la necesidad de implementar buenas prácticas para prevenir riesgos y cumplir con la normativa.

1 CASO PRÁCTICO



WIFI SIN PERMISO

Un técnico de soporte está llevando a cabo tareas de mantenimiento en casa de un cliente. Mientras actualiza el software del router, se da cuenta de que uno de los vecinos está conectado a la red wifi del cliente sin permiso, consumiendo mucho ancho de banda.

Sin decirle nada al cliente, accede al historial de navegación del vecino a través del router y detecta que ha accedido a varias páginas de contenido sensible. Decide hacer una captura de pantalla del registro y la envía a su grupo de WhatsApp con el mensaje: «¡Ualaaaaaaa lo que hace el vecino de este cliente! Flipad 🤯».

Unas semanas después, la persona afectada se entera y presenta una denuncia en la comisaría del barrio.

- » ¿Qué delitos o infracciones ha cometido? ¿Se justifica su actuación por ser un técnico?

- » ¿Qué artículo del **Código Penal** puede aplicarse en este caso por acceder al historial y difundirlo?
- » ¿Qué dice el **RGPD/LOPDGDD** sobre la visualización y difusión de datos personales? ¿El historial de navegación entra dentro de esta categoría?
- » ¿Cuál es la diferencia entre «curiosear» y «acceder sin autorización» desde el punto de vista legal? ¿Cómo se considera eso en el ámbito profesional?
- » ¿Qué buenas prácticas debería seguir un técnico ante una situación similar?

02 Estrategias de mantenimiento y gestión de la seguridad

La Constitución española quiere proteger de una forma muy meticulosa una serie de derechos inherentes a toda persona (los llamados derechos fundamentales). Entre estos destaca **el derecho a la intimidad**. Además de las consecuencias penales que puede comportar la vulneración de este derecho, hay otras leyes, con independencia del marco penal, que igualmente protegen la privacidad de la persona en todos sus aspectos, también en cuanto a sus propios datos.

Como podemos ver, la legislación es muy proteccionista con los datos. Esto afecta de una manera negativa a los sistemas informáticos, a la forma en la que operan las organizaciones e incluso el día a día de las personas. El conjunto de normas existente intenta encontrar un equilibrio entre estos elementos, aparentemente opuestos, para conseguir un adecuado nivel de seguridad de los datos, junto con una protección suficiente de la intimidad, al tiempo que se garantice a las empresas poder operar con la información de una manera eficiente.

2.1. Normativa legal sobre protección de datos personales

En la actualidad, la protección de los datos de carácter personal ha adquirido una gran importancia. Afortunadamente, cada vez más personas son conscientes del valor de su información personal y tienen un mayor cuidado y exigencia respecto a su tratamiento y protección.

Esta mayor concienciación social es fruto, por un lado, del desarrollo de la legislación en materia de protección de datos y, por otro, del papel activo de organismos como la **Agencia Española de Protección de Datos (AEPD)**, entidad pública independiente encargada de velar por el cumplimiento de dicha normativa.

A. Agencias autonómicas de protección de datos

Se han creado cuatro agencias autonómicas: en Madrid en el año 2001, en Cataluña en el 2003, en País Vasco en el 2004 y en Andalucía en 2014, con la particularidad de que, en esta comunidad, la entidad competente en materia de protección de datos lo es también en materia de transparencia. La Agencia de Protección de Datos de la Comunidad de Madrid fue suprimida el 1 de enero de 2013 y sus funciones pasaron a ser asumidas por la Agencia Española de Protección de Datos.

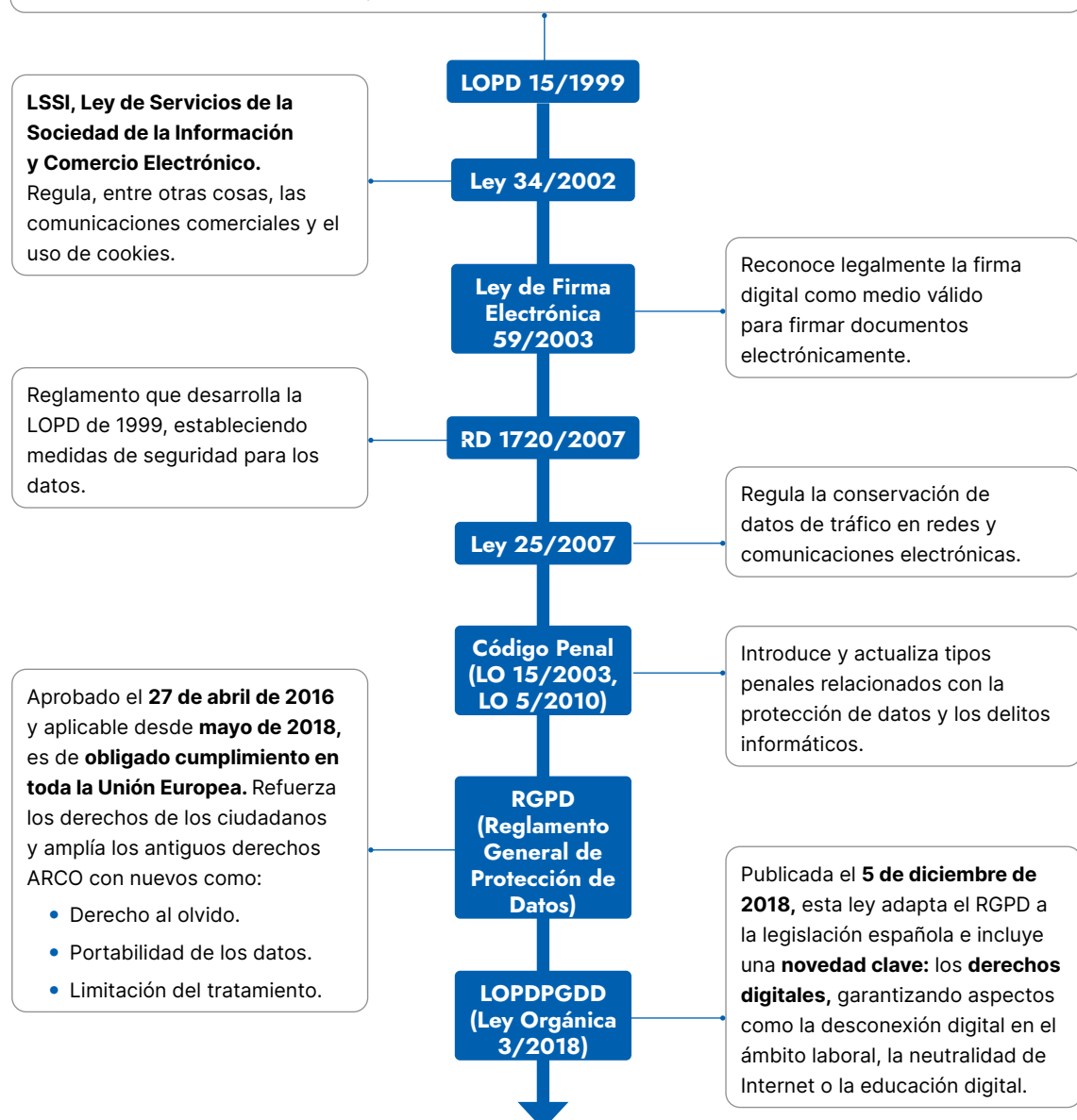
Por tanto, actualmente existen tres agencias autonómicas: la **Autoridad Catalana de Protección de Datos**, la **Agencia Vasca de Protección de Datos** y el **Consejo de Transparencia y Protección de Datos de Andalucía**.

B. Evolución de la legislación sobre protección de datos

A continuación, se presenta un resumen de las principales normas que han marcado el desarrollo legal de la protección de datos en **España y Europa**:

Ley Orgánica de Protección de Datos de Carácter Personal. Fue la primera gran norma española en este ámbito. Tenía como objetivo garantizar los derechos fundamentales de las personas físicas, especialmente su honor, su intimidad y su privacidad en relación con el tratamiento de sus datos personales. Esta ley introdujo los **derechos ARCO**:

- **Acceso:** derecho a conocer qué datos tiene una organización sobre uno mismo.
- **Rectificación:** derecho a corregir datos inexactos o incompletos.
- **Cancelación:** derecho a solicitar la supresión de los datos cuando ya no sean necesarios.
- **Oposición:** derecho a impedir el tratamiento de los datos en ciertos casos (por ejemplo, con fines comerciales sin consentimiento).



C. Reglamento general de protección de datos

El RGPD establece los requisitos específicos para empresas y organizaciones sobre **recogida, almacenamiento y gestión de los datos personales**.

Este se aplicará cuando:

- » La empresa trata datos personales y tiene su sede en la UE, independientemente de dónde se traten de hecho los datos.
- » La empresa tiene su sede fuera de la UE, pero trata datos personales relativos a ofertas de bienes o servicios a ciudadanos en la UE, o supervisa el comportamiento de ciudadanos en la UE.

Las empresas que no tienen sede dentro de la UE y que tratan datos de ciudadanos de la UE deben nombrar un **representante en la UE**.

Este también se nombrará cuando:

- » El interesado haya fallecido.
- » El interesado sea una persona jurídica.
- » El tratamiento de datos se efectúe por una persona que actúa con fines ajenos a sus actividades comerciales, empresariales o profesionales.

D. Definición de datos personales

Los podemos definir como cualquier información relacionada con una persona identificada o identificable, también denominada **«el interesado»**. Ejemplos de datos personales son los siguientes:

- » Nombre y apellidos.
- » Dirección.
- » Número de documento de identidad/pasaporte.
- » Ingresos.
- » Perfil cultural.
- » Dirección de protocolo internet (IP).
- » Datos en poder de hospitales o médicos (que identifican únicamente a una persona con fines sanitarios).

No es posible tratar datos personales sobre:

- » Origen racial o étnico.
- » Opiniones políticas.
- » Datos genéticos, biométricos o sanitarios, salvo en casos específicos (por ejemplo, cuando se da un consentimiento explícito o cuando el tratamiento es necesario por razones de interés público esencial, sobre la base del derecho nacional o de la UE).
- » Orientación sexual.
- » Convicciones religiosas o filosóficas.
- » Afiliación sindical.
- » Condenas e infracciones penales, a menos que lo autorice el derecho nacional o de la UE.

Durante su tratamiento, los datos personales pueden pasar por diferentes empresas u organizaciones. Es un proceso que puede ser complejo y, por eso, hay dos figuras principales que gestionan el tratamiento de esos datos:

- » **El responsable del tratamiento de los datos**, que decide el fin y la forma en que estos se tratan.
- » **El encargado del tratamiento de los datos**, que conserva y trata los datos en nombre de un responsable del tratamiento.

DEFINICIÓN

El **delegado de protección de datos**, que puede ser nombrado por la empresa, es responsable de supervisar cómo se tratan los datos personales y de informar y aconsejar a los empleados que tratan los datos sobre sus obligaciones. El delegado de protección de datos coopera también con la autoridad de protección de datos y sirve de punto de contacto entre estas autoridades y los ciudadanos.

Una empresa en sí tiene la obligación de nombrar a un delegado de protección de datos cuando:

- » Supervise periódica o sistemáticamente a los ciudadanos o trate categorías especiales de datos.
- » El tratamiento de datos sea una actividad empresarial principal.
- » Efectúe el tratamiento de datos a gran escala.

Si los datos personales se tratan para **orientar la publicidad de los motores de búsqueda** en función del comportamiento de las personas, la empresa debe contar con un delegado de protección de datos. Si, no obstante, la empresa solo envía material publicitario a sus clientes muy de vez en cuando, no es necesario un delegado de protección de datos. Del mismo modo, si un médico recoge datos sobre la salud de sus pacientes, probablemente no se necesite un delegado de protección de datos. Pero si se tratan los datos personales sobre genética y salud para un hospital, entonces sí es necesario un delegado de protección de datos.

El delegado de protección de datos puede pertenecer a la plantilla de la organización o puede haber sido contratado externamente a través de un contrato de servicios. Un delegado de protección de datos puede ser un particular o formar parte de una organización.

Un responsable del tratamiento de los datos solo puede recurrir a un encargado del tratamiento que ofrezca garantías suficientes, que deberán incluirse en un contrato escrito entre las partes implicadas. Además, el contrato deberá recoger una serie de cláusulas obligatorias, como, por ejemplo, que el encargado del tratamiento solo podrá tratar datos personales cuando se lo encargue el responsable del tratamiento de los datos.

E. Condiciones para el tratamiento y la transferencia internacional de datos personales según el RGPD

Cuando los datos personales se transfieran fuera de la UE, la protección ofrecida por el RGPD acompañará a los datos. Eso significa que, si los datos se exportan al extranjero, la empresa debe garantizar que se cumpla una de las siguientes condiciones:

- » La protección de datos del país no miembro de la UE se considera adecuada.
- » La empresa toma las medidas necesarias para proporcionar las oportunas salvaguardias, como la inclusión de cláusulas específicas en el contrato celebrado con el importador no europeo de los datos personales.
- » La empresa se basa en motivos específicos para la transferencia (excepciones), como el consentimiento del interesado.

Las normas de protección de datos de la UE establecen que los datos deben tratarse de manera justa y lícita para un fin específico y legítimo y que solo deben tratarse los necesarios para alcanzar ese objetivo. La empresa debe cerciorarse de que se cumple una de las siguientes condiciones para el tratamiento de los datos personales:

- » El interesado ha dado su **consentimiento**.
- » Los datos personales son necesarios para respetar una **obligación contractual** con el interesado.
- » Los datos personales son necesarios para cumplir una **obligación legal**.
- » Los datos personales son necesarios para proteger los **intereses vitales** del interesado.
- » Los datos personales se tratan para una **misión de interés público**.
- » Se actúa en **interés legítimo** de la empresa, siempre que en el tratamiento de los datos del interesado no se vean gravemente afectados los derechos y libertades fundamentales de este; los derechos de esa persona prevalecen sobre los intereses de la empresa, de manera que, si ambos colisionan, no se pueden tratar sus datos personales.

F. Consentimiento y transparencia en el tratamiento de datos personales según el RGPD

El Reglamento General de Protección de Datos aplica normas estrictas para el tratamiento de datos basadas en el consentimiento. El objetivo de estas normas es **garantizar que el interesado comprenda lo que está consintiendo**. Eso significa que el consentimiento debe darse de manera libre, específica, informada e inequívoca, mediante una solicitud presentada en un lenguaje claro y sencillo. El consentimiento se expresará mediante un acto afirmativo, como marcar una casilla online o firmar un formulario.

Cuando una persona consienta el tratamiento de sus datos personales, solo se podrán tratar para los fines para los que haya dado su consentimiento. También debe ofrecérsele la posibilidad de retirar su consentimiento.

Los interesados deben recibir información clara sobre quién trata sus datos personales y por qué. Deben saber al menos lo siguiente:

- » La identidad del responsable.
- » Por qué se tratan sus datos personales.
- » La base jurídica del tratamiento.
- » Quién recibirá los datos (si procede).

En algunos casos, la información proporcionada también debe incluir:

- » La información de contacto del delegado de protección de datos (en su caso).
- » Los intereses legítimos de la empresa si se acoge a esta base jurídica para efectuar el tratamiento.
- » Las medidas aplicadas para la transferencia de los datos a un país no perteneciente a la UE.
- » El periodo de almacenamiento de los datos.
- » Los derechos del interesado en materia de protección de datos (por ejemplo, acceso, rectificación, supresión, limitación, oposición, portabilidad, etc.).
- » El derecho a retirar el consentimiento (cuando el consentimiento sea la base jurídica para el tratamiento).
- » Si la comunicación de datos es un requisito legal o contractual.
- » En caso de decisiones automatizadas, información sobre la lógica aplicada, la importancia y las consecuencias de la decisión.

Toda la información debe presentarse en un lenguaje claro y sencillo.

Cuando se recogen datos personales de menores que se basan en el consentimiento (por ejemplo, para utilizar una red social o para una cuenta de descarga de contenidos), **es preciso obtener primero la autorización parental** (por ejemplo, enviando una notificación al padre, la madre o el tutor). La edad hasta la cual una persona se considera menor varía según el país de residencia, pero se sitúa entre los 13 y los 16 años.

G. Derechos de los interesados en el tratamiento de datos personales según el RGPD

Los ciudadanos deben tener **derecho a acceder a sus datos personales** gratuitamente.

Cuando se recibe una petición de este tipo, es necesario:

- » Indicar si se están tratando los datos personales.
- » Informar sobre el tratamiento (finalidad, categorías de datos personales, destinatarios de los datos, etc.).
- » Entregar una copia de los datos personales objeto de tratamiento (en un formato accesible).

Cuando el tratamiento se base en el consentimiento o en un contrato, el interesado también puede pedir que se le devuelvan sus datos personales o se transmitan a otra empresa. Es lo que se conoce como derecho a la portabilidad de los datos. Los datos deben facilitarse en un formato utilizado habitualmente y de lectura automática.

Si una persona considera que sus datos personales son incorrectos, incompletos o inexactos, tiene **derecho a rectificarlos o completarlos** sin demoras indebidas. En ese caso, se debe notificar a todos los destinatarios de los datos personales si alguno de los datos compartidos con ellos se ha modificado o suprimido. Si los datos personales compartidos son incorrectos, puede ser necesario también informar a todos los que los hayan consultado (a menos que se considere que supone un esfuerzo desproporcionado).

Una persona **también puede oponerse en todo momento al tratamiento de sus datos personales** para un uso específico si la empresa los trata sobre la base de un interés legítimo o para una actividad de interés público. La empresa debe dejar de tratar los datos personales a menos que el interés legítimo prevalezca sobre el interés del interesado.

Del mismo modo, una persona puede solicitar que se limite el tratamiento de sus datos personales mientras se determina si el interés legítimo de la empresa prevalece sobre su interés individual. No obstante, en caso de fines comerciales directos, la empresa siempre tiene la obligación de dejar de tratar los datos personales si lo solicita el interesado.

En determinadas circunstancias, una persona puede solicitar al responsable del tratamiento que suprima sus datos personales, en concreto, si los datos ya no son necesarios para cumplir la finalidad del tratamiento. Sin embargo, la empresa no tiene la obligación de hacerlo si:

- » El tratamiento es necesario para respetar la libertad de expresión y de información.
- » Deben conservarse los datos personales para cumplir una obligación legal.
- » Existen otras razones de interés público para almacenar los datos personales, como de salud pública o con fines de investigación científica e histórica.
- » Deben conservarse los datos personales para emprender una acción legal.

Los interesados tienen **derecho a no ser objeto de una decisión basada únicamente en un tratamiento automatizado**. No obstante, hay algunas **excepciones a esta regla**, como en los casos en que se haya dado un consentimiento explícito a la decisión automatizada. Salvo cuando una decisión automatizada se base en una ley, la empresa debe:

- » Informar al interesado sobre las decisiones automatizadas.
- » Dar al interesado el derecho a que una persona revise la decisión automatizada.
- » Dar al interesado la posibilidad de impugnar la decisión automatizada.

Por ejemplo, si un banco automatiza su decisión de conceder o no un préstamo a una persona, esta debe ser informada de la decisión automatizada y tener la posibilidad de impugnar la decisión y solicitar la intervención humana.

Se considera **violación de datos** la divulgación accidental o ilegal a destinatarios no autorizados de datos que sean responsabilidad de una empresa, así como su indisponibilidad temporal o su modificación. Si se produce una violación de datos que represente un riesgo para los derechos y las libertades individuales, es preciso notificarlo a la autoridad de protección de datos competente en un plazo de 72 horas a partir del momento en que se conozca la infracción.

En caso de que la violación de datos personales entrañe un alto riesgo para las personas afectadas, la empresa también puede estar obligada a informar a todos los afectados.

Si la empresa recibe una **solicitud** de un particular que desea ejercer sus derechos, debe responder a la solicitud sin demoras indebidas y, en cualquier caso, en el plazo de un mes a partir de la recepción de la solicitud. Este plazo puede prorrogarse por un periodo de dos meses en caso de solicitudes complejas o múltiples, siempre y cuando se informe de la prórroga al interesado. Las solicitudes se tramitan gratuitamente. Si la empresa rechaza una solicitud, debe informar al interesado de las razones y de su derecho a presentar una reclamación ante la autoridad de protección de datos.

Es obligatorio realizar una **evaluación de impacto** sobre la protección de datos siempre que el tratamiento previsto pueda **representar un alto riesgo** para los derechos y libertades de las personas, en particular cuando se utilizan nuevas tecnologías.

Existe ese alto riesgo cuando:

- » Se utilicen el tratamiento automatizado y los mecanismos de elaboración de perfiles para evaluar a las personas.
- » Se observe a gran escala una zona de acceso público (por ejemplo, con circuito cerrado de televisión).
- » Se traten a gran escala categorías especiales de datos (por ejemplo, datos sanitarios) o datos personales relativos a condenas e infracciones penales.

Las autoridades de protección de datos pueden considerar de alto riesgo **otras categorías** de tratamiento de datos.

Si las medidas indicadas en la evaluación del impacto sobre la protección no eliminan todos los altos riesgos identificados, debe consultarse a la autoridad de protección de datos antes de que se lleve a cabo el tratamiento.

La empresa debe demostrar que actúa de conformidad con el Reglamento General de Protección de Datos y cumple todas las obligaciones aplicables, especialmente a petición o bajo la inspección de la autoridad de protección de datos.

Una manera de hacerlo es mantener **registros detallados** de aspectos tales como:

- » Nombre y datos de contacto de la empresa que intervenga en el tratamiento de datos.
- » Razones para el tratamiento de los datos personales.
- » Descripción de las categorías de personas que proporcionan datos personales.
- » Categorías de organizaciones que reciben los datos personales.
- » Transferencia de datos personales a otro país u organización.
- » Periodo de almacenamiento de los datos personales.
- » Descripción de las medidas de seguridad utilizadas en el tratamiento de los datos personales.

La empresa debe también conservar, y actualizar periódicamente, las directrices y procedimientos escritos y darlos a conocer a sus empleados. Si se trata de una pyme o una empresa más pequeña, no es necesario mantener registros de las actividades de tratamiento siempre que:

- » No se hagan habitualmente.
- » No afecten a los derechos o libertades de los interesados.
- » No traten datos confidenciales o registros de antecedentes penales.

El incumplimiento del Reglamento General de Protección de Datos puede dar lugar a multas de hasta 20 millones de euros o del 4 % del volumen de negocios mundial de la empresa, en determinadas infracciones. La autoridad de protección de datos puede imponer medidas correctivas adicionales, como obligar a poner término al tratamiento de los datos personales.

2.2. Sistemas de seguridad para el acceso a datos personales almacenados

La protección de los datos personales requiere un **control de acceso muy riguroso**, limitándolo solo a los usuarios autorizados. Quizá la primera medida que se debería considerar es el control de acceso físico a los sistemas informáticos. Esta medida, que puede parecer obvia, es una de las más importantes y, paradójicamente, una de las más descuidadas. Una empresa puede invertir una fortuna en software para evitar accesos no autorizados, pero todo este esfuerzo será inútil si se puede acceder físicamente a los sistemas informáticos.

El hardware suele ser el elemento más caro de un sistema informático y, por lo tanto, se debe tener especial cuidado con las personas que tienen acceso físico a él. Una persona no autorizada y que acceda al sistema podría causar unos problemas importantes, como el robo de ordenadores, la introducción de malware en el servidor (por ejemplo, un troyano o un keylogger), la destrucción de datos, etc.

DEFINICIÓN

Un **keylogger** es un software o hardware que registra la actividad de un teclado en una estación de trabajo.

Respecto a los **troyanos**, son fragmentos de código insertados en software que se utiliza habitualmente en el sistema. Este código permanece oculto y realiza tareas sin que el usuario o el administrador se den cuenta. Camuflados bajo la apariencia de un software útil o común, no suelen causar efectos destructivos. Generalmente, capturan contraseñas y otros datos confidenciales y los envían por correo electrónico a la persona que ha introducido el troyano en el sistema atacado.

Para evitar este tipo de problemas, se pueden adoptar diversas **medidas**, la mayoría de sentido común:

- » Mantener los servidores y todos los elementos centrales del sistema en una zona de acceso físico restringido.
- » Mantener los dispositivos de almacenamiento en un lugar diferente al resto del hardware.
- » Realizar inventarios o registros de todos los elementos del sistema informático (útil en casos de robo).

- » Proteger y aislar el cableado de la red (tanto para protegerlo de daños físicos como del espionaje).
- » Instalar cámaras de videovigilancia.
- » Utilizar contraseñas en los salvapantallas.
- » Utilizar contraseñas de BIOS.
- » Desactivar las opciones de autocompletar y recordar contraseñas en los navegadores de Internet.
- » Elegir una topología de red adecuada a nuestras necesidades de seguridad.
- » Garantizar la seguridad del hardware de red (routers, conectores, concentradores y módems).
- » Mantener el sistema informático actualizado.
- » Disponer de mecanismos de autenticación para los usuarios que deseen acceder al sistema.

La **BIOS** (sistema básico de entrada/salida) es un programa almacenado en un chip ROM que se encarga, en el momento en que el ordenador se inicia, de cargar el sistema operativo en la memoria del ordenador y verificar los dispositivos conectados.

A. Autenticación

La podemos definir como el procedimiento de verificación de la identidad de una persona o proceso que desea acceder a los recursos de un sistema informático.

Un mecanismo de autenticación puede situarse en varios **niveles**:

- » Instalado en la BIOS.
- » Instalado en el sector de arranque del equipo.
- » Solicitado por el sistema operativo.
- » Solicitado por un software.

Existen diversos tipos de autenticación, desde los más económicos y sencillos (como un nombre de usuario y una contraseña) hasta los más costosos y complejos (como un escáner de retina). La elección del mecanismo adecuado dependerá de las necesidades y el presupuesto de la empresa. Además, muchos de estos mecanismos son complementarios y pueden utilizarse simultáneamente. Estos son los tipos:

» **Sistemas basados en elementos conocidos por el usuario:** el principal mecanismo dentro de este tipo de autenticación son los sistemas basados en contraseñas. Es uno de los métodos más utilizados para autenticar a un usuario que desea acceder a un sistema. Aunque es el método más económico, también es el más vulnerable, ya que las contraseñas, aunque deberían ser personales e intransferibles, a menudo acaban en manos de personas no autorizadas. Además, aunque las contraseñas se almacenen cifradas en un archivo, es posible descifrarlas con múltiples técnicas. Estas son algunas recomendaciones para el uso de contraseñas:

- Memorizarla y no llevarla escrita.
- Cambiarla periódicamente (por ejemplo, mensualmente).
- No repetir la misma contraseña en diferentes cuentas.
- No tirar documentos con contraseñas a la papelera.
- Evitar utilizar palabras de diccionario.
- Evitar utilizar datos que puedan ser conocidos por otras personas (como el nombre, DNI, número de móvil, etc.).
- Utilizar contraseñas de al menos ocho caracteres.
- Evitar la reutilización de contraseñas antiguas.
- No utilizar contraseñas exclusivamente numéricas.
- Incluir caracteres especiales (¡, *, ?, etc.).
- Evitar secuencias de teclado como «qwerty».
- Utilizar reglas mnemotécnicas para recordar las contraseñas.

Muchos sistemas informáticos obligan a los usuarios a elegir contraseñas con un cierto nivel de robustez: exigen cambiar la contraseña periódicamente, que tenga un número mínimo de caracteres, etc.

» **Sistemas basados en elementos que posee el usuario:** en este caso, la autenticación no se basa en lo que el usuario recuerda o conoce, sino en un dispositivo que lleva consigo (que también puede requerir la introducción de una contraseña o un número PIN) o en las propias características físicas del usuario (sistemas biométricos).

» **Sistemas basados en tarjetas inteligentes y tokens de seguridad:** una tarjeta inteligente (smartcard) es similar a una tarjeta de crédito, pero, a diferencia de estas, las tarjetas inteligentes alojan un microprocesador (y memoria) que les permite:

- Realizar cálculos criptográficos sobre la información que almacenan.
- Almacenar información cifrada.
- Proteger físicamente la información almacenada.
- Almacenar claves de firma digital y cifrado.

Un ejemplo de tarjeta inteligente es el **DNI electrónico español (DNle)**. Estas tarjetas pueden ser de contacto (deben insertarse en un lector) o sin contacto, como las utilizadas en los sistemas de pago de transporte público.

» **Sistemas biométricos:** se basan en las características físicas del usuario que se desea autenticar (como huellas dactilares, reconocimiento facial, etc.). La principal ventaja es que el usuario no necesita recordar contraseñas ni llevar consigo ningún dispositivo. Aunque suelen ser más caros que otros métodos, algunos sistemas biométricos, como el reconocimiento dactilar, ofrecen un alto nivel de seguridad a un precio razonable. Estas son algunas características biométricas comunes:

- Voz.
- Huellas dactilares.
- Patrones de la retina o del iris.
- Geometría de la mano.
- Estructura facial.
- Reconocimiento de venas.

B. Protección de datos mediante criptografía

Para garantizar que la información solo sea accesible por parte de usuarios autorizados y evitar que la información en claro (sin cifrar) que circula por una red pueda ser interceptada, se pueden utilizar diversos métodos criptográficos:

- » **Criptosistema de clave privada (simétrico):** también se conoce como cifrado de clave privada. La clave que se usa en la codificación es la misma que se utiliza en la decodificación, lo que resulta más conveniente para usuarios individuales y sistemas cerrados. Por otro lado, se debe enviar la clave al receptor. Esto aumenta el riesgo de que quede comprometida si la intercepta un tercero como un hacker. Este método es más rápido que el método asimétrico. Algunos ejemplos son AES (Advanced Encryption Standard), DES (Data Encryption Standard) y 3DES (Triple DES).
- » **Criptosistema de clave pública (asimétrico):** en estos sistemas, se usan dos claves distintas, pero relacionadas matemáticamente: una clave pública y una clave privada. La clave pública se distribuye libremente y se utiliza para cifrar mensajes, mientras que la clave privada se mantiene en secreto y se usa para descifrarlos. Esto permite que cualquiera pueda enviar mensajes seguros sin compartir previamente una clave secreta. Además, se puede usar para firmar digitalmente mensajes, garantizando autenticidad e integridad. Ejemplos comunes de este tipo son RSA, ECC (curvas elípticas) o ElGamal.
- » **Firma digital:** permite autenticar la identidad del emisor de un mensaje. El emisor firma el mensaje con su clave privada y el receptor verifica la firma utilizando la clave pública del emisor. Esto garantiza la no repudiación, es decir, que el emisor no puede negar que envió el mensaje.
- » **Certificado digital:** es una firma digital que se instala en el navegador para garantizar su identidad en Internet y que permite realizar gestiones desde el ordenador, el dispositivo móvil o la tablet ante la Administración pública.

2.3. Legislación sobre los servicios de la sociedad de la información, comercio electrónico, correo electrónico y firma electrónica

El crecimiento exponencial del uso de Internet ha provocado que actividades que antes solo pasaban en el mundo real ocurran ahora en un ámbito virtual. Un ejemplo actual es el comercio electrónico y el envío de emails. Estos cambios han generado nuevas necesidades en las leyes, las cuales se tienen que adaptar y ampliar para afrontar los nuevos desafíos derivados del uso de las tecnologías de la información. No se trata solo de prevenir el mal uso de estas tecnologías (como el envío de correo no deseado o spam), sino también de crear un entorno de confianza; en definitiva, un entorno digital más seguro y confiable donde se definan con claridad las responsabilidades y obligaciones de todos los actores (usuarios, administraciones, empresas...). Esto es necesario y fundamental para el desarrollo seguro de transacciones como el comercio electrónico.

DEFINICIÓN

Podemos definir **e-commerce** como la compra y venta de productos o servicios a través de Internet. Para regular estas actividades, se creó la **Ley 34/2002, de 11 de julio**, de Servicios de la Sociedad de la Información y de Comercio Electrónico (LSSICE), que adapta las normas europeas al marco jurídico español.

Con una evolución continua de la tecnología, esta normativa ha necesitado varias actualizaciones, entre las que destaca la incorporación del **Reglamento (UE) 2016/679**, más conocido como Reglamento General de Protección de Datos (RGPD), que refuerza la protección de datos personales y garantiza la privacidad en las transacciones electrónicas.

A. Servicios de la sociedad de la información

Según la LSSICE, los servicios de la sociedad de la información incluyen una amplia variedad de actividades, tales como:

- » Contratación de bienes y servicios por vía electrónica.
- » Suministro de información por vía electrónica (por ejemplo, periódicos digitales).
- » Actividades de intermediación, como:
 - Provisión de acceso a la red.
 - Transmisión de datos.
 - Alojamiento de datos en servidores.

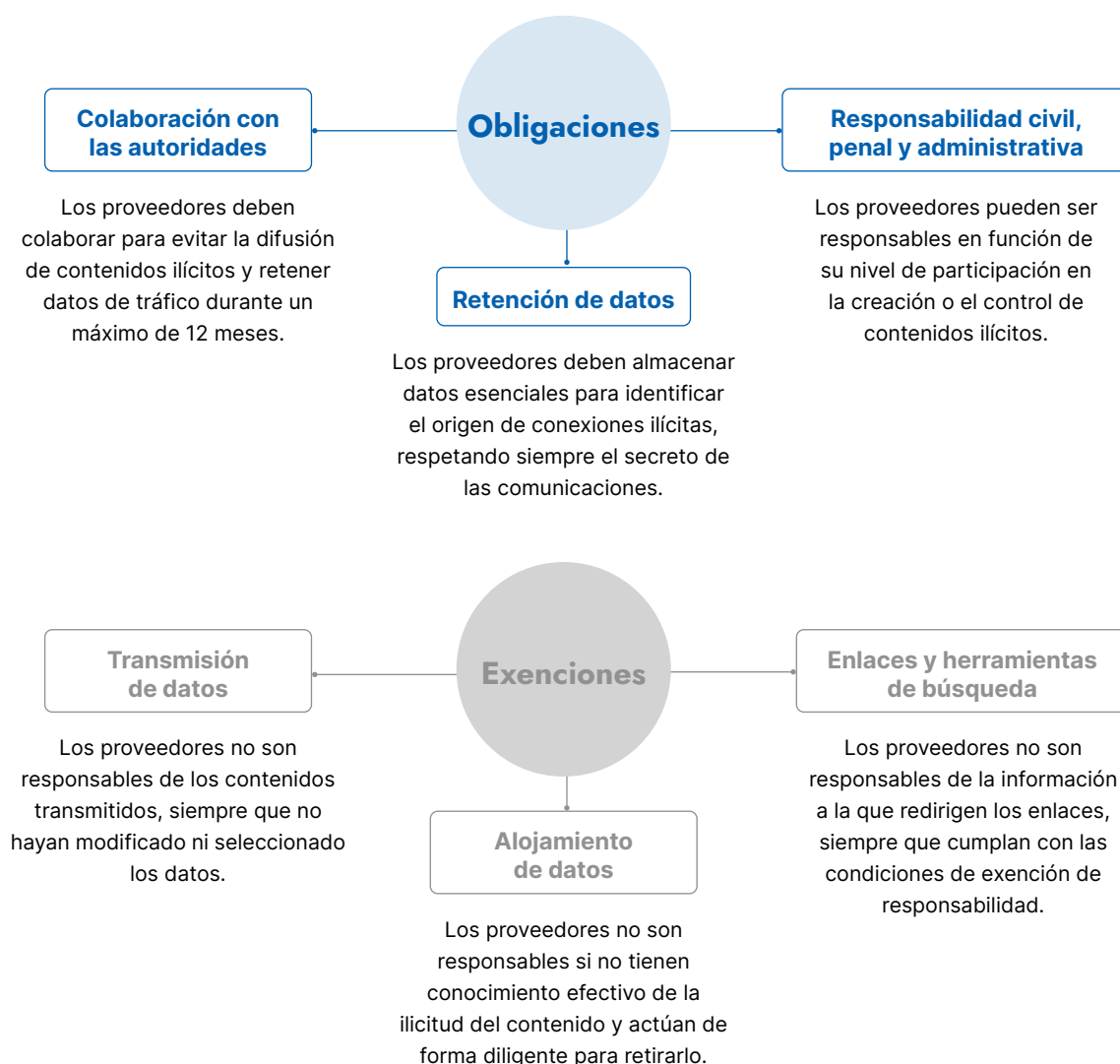
- Provisión de herramientas de búsqueda.
- Enlaces a otros sitios web.

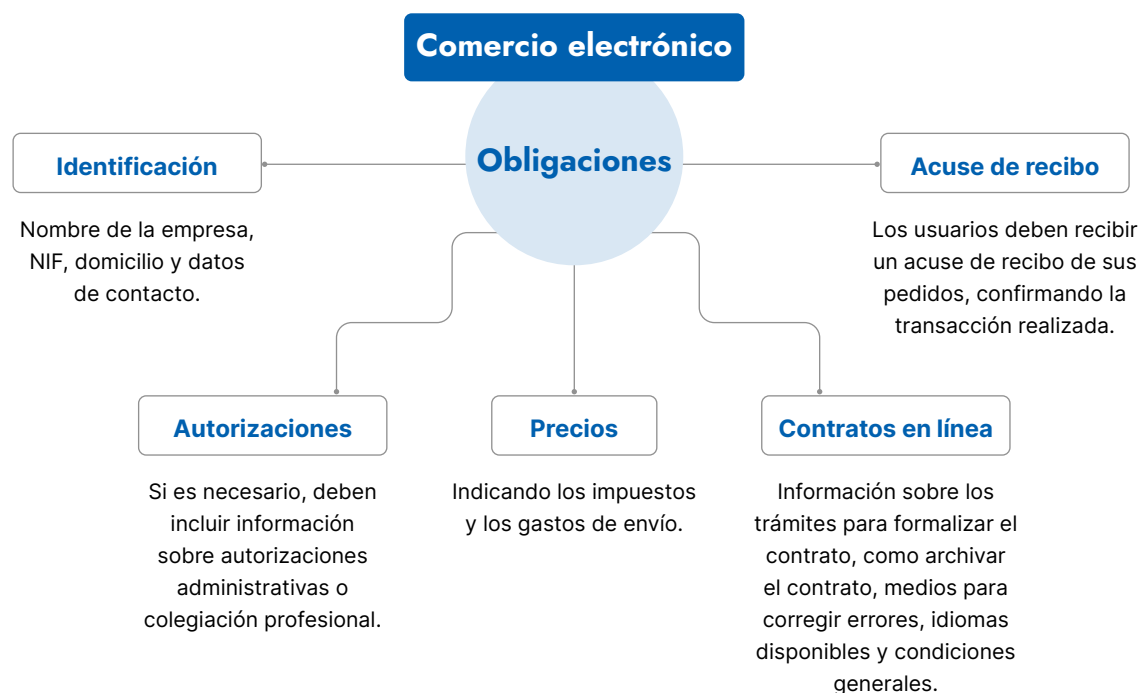
» Cualquier otro servicio que se preste a petición individual de los usuarios (descarga de archivos de vídeo o audio...), siempre que represente una actividad económica para el proveedor.

Los proveedores de estos servicios incluyen operadores de telecomunicaciones, proveedores de acceso a Internet, portales, motores de búsqueda y cualquier entidad que ofrezca servicios a través de Internet, incluyendo el comercio electrónico.

B. Normas y responsabilidades de las empresas que prestan servicios por Internet

La **LSSICE** establece las obligaciones y responsabilidades de los proveedores de servicios con el fin de fomentar un entorno de confianza y combatir actividades ilícitas en la Red. Es relevante señalar que esta ley se enmarca en el ámbito extrapenal, por lo que las sanciones no incluyen penas privativas de libertad.





C. Normas sobre el envío de publicidad no deseada (spam)

El **correo no deseado** o spam consiste en el envío masivo de mensajes no solicitados con fines comerciales. Aunque no está tipificado como delito en el Código Penal, su regulación se encuentra en:

- » **Ley Orgánica 3/2018, de 5 de diciembre**, de Protección de Datos Personales y Garantía de los Derechos Digitales (LOPDPGDD): adaptada al Reglamento General de Protección de Datos (RGPD), establece que el consentimiento explícito del destinatario es obligatorio para el envío de publicidad.
- » **LSSICE:** prohíbe el envío de comunicaciones comerciales no autorizadas, con sanciones que pueden ascender hasta los 150 000 €.

Los usuarios tienen derecho a no recibir publicidad no solicitada y pueden retirar su consentimiento en cualquier momento.

D. Legislación sobre la firma electrónica

La firma electrónica es un elemento clave para garantizar la seguridad y la confianza en las transacciones digitales. La **Ley 59/2003, de 19 de diciembre**, de Firma Electrónica, regula este ámbito en España. Esta ley ha sido adaptada a la legislación europea mediante el **Reglamento (UE) n.º 910/2014** del Parlamento Europeo y del Consejo, de 23 de julio de 2014, sobre la identificación electrónica y los servicios de confianza para las transacciones electrónicas en el mercado interior (reglamento eIDAS).

Los tipos de firma electrónica son:

- » **Firma electrónica avanzada:** permite identificar al firmante y detectar modificaciones en los datos firmados.
- » **Firma electrónica reconocida:** equiparada a la firma manuscrita, se basa en un certificado reconocido y se genera mediante un dispositivo seguro.

Las propiedades de la firma digital son:

- » **Autenticidad:** garantiza la identidad del firmante.
- » **Integridad:** asegura que el contenido no ha sido alterado.
- » **No repudiación:** impide que el firmante niegue la autoría del documento.

Las **autoridades de certificación** son entidades que emiten certificados electrónicos, vinculando las herramientas de firma digital con la identidad del usuario. Estos certificados son esenciales para garantizar la autenticidad y la integridad de las transacciones en línea.

2.4. Configuración de programas cliente de correo electrónico para el cumplimiento de normas sobre gestión de seguridad de la información

El email es una herramienta indispensable en nuestra sociedad, tanto en el ámbito profesional como en el personal, pero su uso conlleva riesgos de seguridad y privacidad. Por ello, es necesario configurar correctamente el email y cumplir con las normas de gestión de datos.

A continuación, podemos ver las partes de las que consta el email y las buenas prácticas para asegurar su buen funcionamiento.

Para que el email funcione de forma correcta, se necesitan los siguientes elementos:

- » **Dirección de correo electrónico:** es necesaria tanto para el remitente como para el destinatario. Una dirección de email tiene dos partes: el nombre de usuario (a la izquierda del símbolo @) y el dominio (a la derecha del símbolo @). Por ejemplo, usuario@dominio.com.
- » **Servidor de correo:** es el sistema que gestiona el envío, la recepción y el almacenamiento de emails. Para usar un servidor de correo, es necesario registrarse, lo que permite obtener una dirección de correo única y acceder con un nombre de usuario y contraseña.

- » **Cliente de correo:** es el software que permite gestionar diferentes cuentas de email. Los clientes de correo, como **Thunderbird**, **Outlook** o **Apple Mail**, se configuran con los parámetros proporcionados por el proveedor de correo (tipo de conexión —POP o IMAP—, dirección del servidor, nombre de usuario y contraseña). Estos programas permiten descargar correos al ordenador y enviar nuevos mensajes.
- » **Mensaje de correo:** un mensaje de email es un archivo con un formato específico (definido en el **RFC 822**). A menos que se utilicen medidas de seguridad adicionales, **los correos electrónicos viajan sin cifrar** a través de múltiples servidores en Internet. Esto implica que pueden ser **interceptados** por atacantes si se monitorea el tráfico de red y que el contenido puede ser **leído o modificado** por intermediarios. Para proteger un correo, se pueden usar tecnologías como:
 - **TLS (Transport Layer Security):** cifra la conexión entre servidores de correo. Es útil, pero no garantiza que el contenido esté cifrado de extremo a extremo.
 - **PGP (Pretty Good Privacy) o S/MIME:** estas opciones **cifran el contenido del mensaje**, de modo que solo el destinatario autorizado pueda leerlo. Esto sí protege contra accesos no autorizados incluso si el mensaje es interceptado.

A. Normativa aplicable al correo electrónico

El uso del correo electrónico está regulado por varias normas que garantizan la privacidad y la seguridad de las comunicaciones:

- » Constitución española (artículo 18).
- » Código Penal (artículo 197.1).
- » Estatuto de los Trabajadores (artículo 20.3): permite a los empleadores implementar medidas de vigilancia y control para verificar el cumplimiento de las obligaciones laborales, siempre que se respete la privacidad de los trabajadores.
- » Reglamento General de Protección de Datos (RGPD): regula el tratamiento de datos personales, incluyendo los contenidos en correos electrónicos, y exige medidas de seguridad para proteger la información.
- » Ley Orgánica de Protección de Datos Personales y Garantía de los Derechos Digitales (LOPDPGDD): adapta la legislación española al RGPD y refuerza los derechos digitales de los ciudadanos.

Los servidores de correo almacenan datos personales, por lo que tienen que cumplir la **LOPDGDD** y el **RGPD**. Las medidas técnicas y organizativas que se aplican a los servidores de correo incluyen:

- » **Cifrado de datos:** para proteger la información almacenada.
- » **Acceso restringido:** solo personal autorizado puede acceder a los datos.
- » **Retención de datos:** los emails deben almacenarse durante un tiempo limitado y eliminarse cuando ya no sean necesarios.
- » **Auditorías periódicas:** para garantizar el cumplimiento de las normativas de protección de datos.

B. Configuración de programas cliente de correo para garantizar la privacidad

Para proteger la privacidad y la seguridad de los emails, es necesario configurar de forma adecuada los clientes de correo. Algunas recomendaciones son:

- » **Usar software actualizado:** para corregir las vulnerabilidades.
- » **Eliminar información comprometida:** borrar correos antiguos, cookies y otros datos residuales que puedan comprometer la privacidad.
- » **Usar cuentas de correo separadas:** utilizar una cuenta de correo para asuntos personales y otra para el trabajo.
- » **Cifrar y firmar correos confidenciales:** el cifrado protege el contenido del correo, mientras que la firma digital garantiza la autenticidad del remitente.
- » **Evitar la revelación de datos personales innecesarios:** no compartir información personal en formularios o emails a menos que sea estrictamente necesario.

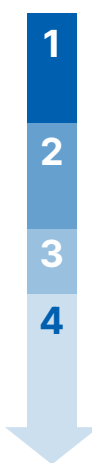
Un correo seguro debe cumplir con las siguientes propiedades:

- » **Cifrado:** garantiza que solo el destinatario pueda leer el mensaje.
- » **Integridad:** asegura que el mensaje no ha sido alterado durante la transmisión.
- » **Autenticidad:** verifica la identidad del remitente.
- » **No repudio:** impide que el remitente niegue haber enviado el mensaje.

Para lograr que se cumplan estas propiedades, se utilizan herramientas como:

- » **Firma digital:** permite al destinatario verificar que el mensaje no ha sido modificado y que proviene del remitente correcto.
- » **Cifrado de correos:** oculta el contenido del mensaje para que solo el destinatario pueda leerlo.
- » **Funciones resumen (hash):** generan una «huella digital» del mensaje, que se utiliza para verificar su integridad.

Para configurar un correo seguro, debemos seguir estos **pasos**:

- 
- 1 Generar un par de claves:** cada usuario debe tener una **clave pública** (para cifrar mensajes) y una **clave privada** (para descifrar mensajes y firmar correos).
 - 2 Firmar el mensaje:** el remitente genera un resumen del mensaje (hash) y lo cifra con su clave privada para firmarlo.
 - 3 Enviar el mensaje:** el mensaje y la firma digital se envían al destinatario.
 - 4 Verificar la firma:** el destinatario genera un resumen del mensaje recibido y lo compara con el resumen descifrado usando la clave pública del remitente. Si coinciden, el mensaje es auténtico y no ha sido alterado.

C. Herramientas

- » **Mozilla Thunderbird:** es un cliente de correo electrónico multiplataforma, libre y de código abierto, cliente de noticias, cliente de RSS y de chat desarrollado por la Fundación Mozilla. Utiliza el lenguaje de interfaz XUL y viene instalado por defecto en los sistemas de escritorio de diversas distribuciones Linux. Se pueden utilizar cifrados y firmas digitales gracias a extensiones como Enigmail.
- » **Microsoft Outlook:** admite el cifrado de mensajes de Microsoft 365 siempre que el servidor de correo electrónico tenga una licencia de Office 365 Enterprise E3. Si no es así, puede cifrar mensajes con S/MIME.
- » **GnuPG (GPG):** es una implementación completa y gratuita del estándar OpenPGP, también conocido como PGP. GnuPG nos permite usar criptografía simétrica y asimétrica para cifrar y firmar datos.
- » **ProtonMail:** es un servicio de email que integra cifrado de extremo a extremo y no monitoriza los correos. ProtonMail cifra los datos en los servidores, impidiendo incluso que la misma empresa pueda leer los correos. La idea es ofrecer un **servicio que garantice una gran privacidad a los usuarios**.

2 CASO PRÁCTICO



CORREOS PROMOCIONALES NO SOLICITADOS

Eres socio de una pequeña tienda de productos artesanales. Decidís lanzar un negocio en línea y contratar a una empresa para crear la tienda web. Se os ofrece un contrato que incluye servicios de envío de newsletters promocionales a los clientes.

Después de unas semanas, algunos clientes se quejan de recibir correos promocionales sin haberlos solicitado. Además, uno de ellos detecta que en el formulario de compra no aparecían los términos del contrato claramente, ni se detallaban los gastos de envío. Una de tus socias, preocupada, revisa el contrato y se da cuenta de que la empresa que contratasteis nunca informó de que debía contar con el consentimiento explícito para enviar estos correos ni ayudó a cumplir con las condiciones legales del comercio electrónico.

- » ¿Qué leyes se están vulnerando en este caso según la LSSICE y el RGPD?
- » ¿Qué obligaciones debió haber cumplido nuestra empresa como comerciante en línea?
- » ¿Qué responsabilidades legales tiene la empresa que diseñó su web?
- » ¿Qué recomendaciones harías para corregir y prevenir este tipo de situaciones en el futuro?

Solucionario casos prácticos

1

SOLUCIÓN CASO PRÁCTICO



WIFI SIN PERMISO

El técnico ha cometido varias **acciones ilegales**:

- » **Accede sin autorización** al historial de navegación de una persona conectada a una red que no es suya.
- » **Difunde información personal y sensible** (historial web) sin consentimiento.
- » **Vulnera la privacidad** de esa persona sin justificación legal.

Aunque sea un profesional del sector, **no tiene derecho a invadir la intimidad de terceros**, especialmente si no existe una solicitud expresa ni consentimiento del afectado o del titular de los datos. Podría ser sancionado según el **artículo 197.1 del Código Penal**.

En este caso, acceder al **historial de navegación** y **difundirlo por WhatsApp** puede ser considerado delito **contra la intimidad personal**.

El **historial de navegación** contiene **datos personales**: revela hábitos, intereses e incluso información sensible (salud, religión, orientación, etc.). Según el RGPD, su tratamiento solo es lícito si existe **consentimiento expreso** o una base legal legítima. El técnico no tenía ninguna base legal ni autorización.

Según el artículo 4 de la LOPDGDD, «los datos personales deben ser tratados de manera leal, lícita y transparente». Por tanto, el técnico actuó fuera de su responsabilidad profesional y sin legitimidad.

«Curiosear» puede sonar coloquial, pero legalmente, en el ámbito profesional, **acceder a información sin autorización es delito**. Aunque no haya un «robo» como tal, el simple **acceso a datos privados sin consentimiento** ya es punible según el **artículo 197 del CP**.

En un entorno técnico, la confianza depositada en el profesional **implica mayor responsabilidad legal y ética**.

Lo que debería haber hecho el técnico es lo siguiente:

- » Informar al cliente de que su red ha sido usada por un vecino sin su consentimiento.
- » Mejorar la seguridad del wifi (cambiar password, desactivar WPS, etc.).
- » Nunca revisar o registrar contenido del usuario conectado sin orden judicial o consentimiento.
- » Si se detecta algo ilegal, comunicarlo a las autoridades, no actuar por cuenta propia ni divulgarlo.

2 SOLUCIÓN CASO PRÁCTICO



CORREOS PROMOCIONALES NO SOLICITADOS

Las leyes vulneradas son:

- » **La LSSICE (Ley 34/2002)**: artículos 10, 20, 21 y 27.
- » **El RGPD (Reglamento UE 2016/679)**: artículo 6, según el cual todo tratamiento de datos (incluido el envío de correos) debe contar con una base legal, como el consentimiento explícito, y artículos 13 y 14, que establecen el deber de informar de forma clara y completa a los interesados sobre el uso de sus datos.

Se debe obtener el **consentimiento explícito** de los clientes antes de enviarles comunicaciones comerciales e informar claramente en su web sobre:

- » Identidad fiscal (nombre, NIF, contacto).
- » Condiciones del servicio, precios, impuestos y gastos de envío.
- » El proceso de compra y contratación, incluyendo la aceptación de condiciones.
- » Garantizar el cumplimiento del RGPD mediante cláusulas de protección de datos y formularios transparentes.

Aunque el responsable final son los socios del comercio, la empresa desarrolladora puede ser **corresponsable** si:

- » No informó adecuadamente sobre los requerimientos legales.
- » Incorporó formularios sin cumplir la normativa sobre consentimiento.
- » Diseñó una web que facilita el incumplimiento de la legislación vigente.

Podría derivarse una **responsabilidad contractual o incluso civil** si se demuestra que su actuación ha causado perjuicios o ha inducido a la infracción.

Algunas **recomendaciones** para corregir y prevenir futuras infracciones pueden ser:

» **Acciones correctivas inmediatas:**

- Suspender temporalmente el envío de correos hasta revisar los consentimientos.
- Modificar los formularios de la web para incluir casillas de aceptación explícita del envío de comunicaciones.

» **Cumplimiento legal:**

- Redactar una política de privacidad clara y accesible.
- Incluir condiciones de contratación visibles antes de confirmar las compras.
- Revisar los textos legales del sitio con asesoramiento jurídico especializado.

» **Formación y supervisión:**

- Capacitarse sobre la LSSICE y el RGPD o contar con asesoría especializada.
- Evaluar con regularidad el cumplimiento normativo de la tienda online.

Enlaces de interés

Agència Catalana de Protecció de Dades (APDCAT): <https://apdc.cat/gencat.cat/>

Agencia Española de Protección de Datos (AEPD): <https://www.aepd.es>

Agencia Vasca de Protección de Datos: <http://www.avpd.euskadi.net/>

Canon digital: https://es.wikipedia.org/wiki/Canon_digital

Certificado digital:

<https://www.xataka.com/basics/certificado-digital-que-que-tipos-hay-como-solicitarlo-activarlo>

Cifrado de correo electrónico: <https://www.avg.com/es/signal/email-encryption>

Consejo de Transparencia y Protección de Datos de Andalucía:

<https://www.ctpdandalucia.es/>

Criptografía AES: <https://www.youtube.com/watch?v=wDpqgrasDmxM>

Delito de revelación de secretos:

<https://www.pgsabogadospenalistas.com/blog/delito-revelacion-secretos/>

Firma electrónica avanzada:

<https://www.signaturit.com/es/blog/firma-electronica-simple-vs-avanzada/>

GnuPG (GPG): <https://www.gnupg.org/>

INCIBE (Instituto Nacional de Ciberseguridad): <https://www.incibe.es>

Pharming vs. phishing:

<https://www.consultoria-conversia.es/ciberseguridad/sabes-lo-que-es-el-pharming-y-en-que-se-diferencia-del-phishing/>

Ransomware vs. malware:

<https://www.keepersecurity.com/blog/es/2023/11/21/ransomware-vs-malware-whats-the-difference/>

Sociedad General de Autores y Editores (SGAE): <https://www.sgae.es/>

Glosario

- » **Acceso no autorizado:** Acción de obtener acceso a un sistema, red o información sin el permiso del propietario o responsable de esos recursos.
- » **Análisis forense informático:** Proceso de investigación de incidentes de seguridad informática para recolectar, preservar, analizar y presentar evidencia digital con el fin de detectar delitos informáticos y proteger los sistemas de posibles amenazas.
- » **Autenticación biométrica:** Método de verificación de identidad basado en las características físicas del usuario, como las huellas dactilares y el reconocimiento facial o del iris, para asegurar el acceso a los sistemas.
- » **Autoridad de protección de datos:** Organismo encargado de supervisar y garantizar el cumplimiento de las leyes de protección de datos personales en una jurisdicción determinada. En nuestro país, la autoridad es la Agencia Española de Protección de Datos (AEPD).
- » **Ciberacoso:** Acoso a través de medios digitales, como las redes sociales o los correos electrónicos, con el objetivo de intimidar o amenazar a la víctima.
- » **Ciberdefensa:** Conjunto de medidas, políticas y prácticas diseñadas para proteger los sistemas informáticos y las infraestructuras críticas de ataques cibernéticos que puedan poner en peligro la seguridad nacional o la estabilidad económica.
- » **Ciberseguridad:** Prácticas, tecnologías y procesos diseñados para proteger sistemas informáticos, redes y datos de accesos no autorizados, ataques o daños.
- » **Cifrado:** Técnica utilizada para convertir la información en un formato ilegible para personas no autorizadas. Solo aquellos con la clave de cifrado pueden descifrar y acceder a la información original.
- » **Código Penal:** Conjunto de normas legales que definen los delitos y establecen las sanciones correspondientes, incluyendo los relacionados con la informática y la protección de datos.
- » **Consentimiento informado:** Aprobación explícita otorgada por el interesado para el tratamiento de sus datos personales, tras haber sido informado de manera clara sobre el uso que se les dará.

- » **Copia de seguridad (backup):** Copia duplicada de los datos de un sistema que se utiliza para recuperar la información original en caso de pérdida, daño o ataque cibernético.
- » **Criptografía de clave pública:** Sistema criptográfico que utiliza un par de claves: una pública, que se puede compartir abiertamente, y una privada, que debe mantenerse en secreto.
- » **Criptojacking:** Uso no autorizado de los recursos de un dispositivo para minar criptomonedas sin el conocimiento o permiso del propietario.
- » **Datos sensibles:** Tipo de datos personales que requieren una protección especial, como los relacionados con la salud, la orientación sexual, la raza, las creencias religiosas o las afiliaciones políticas.
- » **DDoS (denegación de servicio distribuida):** Tipo de ataque en el que múltiples sistemas envían grandes volúmenes de tráfico a un servidor con el objetivo de hacer que este se caiga o no responda.
- » **Delegado de protección de datos (DPD):** Persona designada dentro de una organización para supervisar el cumplimiento de la legislación de protección de datos y garantizar la privacidad de la información tratada.
- » **Delito informático:** Conducta delictiva que se comete utilizando medios informáticos, como el acceso no autorizado a sistemas, la distribución de malware o el fraude en línea.
- » **Derechos arco:** Son los derechos que tienen los individuos sobre sus datos personales, permitiéndoles acceder, rectificar, cancelar u oponerse al tratamiento de sus datos.
- » **Encargado del tratamiento:** Persona o entidad que procesa los datos personales en nombre del responsable del tratamiento, siguiendo sus instrucciones.
- » **Espionaje industrial:** Robo o acceso no autorizado a la información confidencial de una empresa, como secretos comerciales o datos sensibles, con el objetivo de obtener una ventaja competitiva.
- » **Evaluación de impacto sobre la protección de datos (EIPD):** Evaluación realizada por las organizaciones para identificar los riesgos que suponen para los derechos y libertades de las personas los tratamientos de datos personales, y para tomar medidas que mitiguen esos riesgos.
- » **Falsificación documental:** Creación o modificación fraudulenta de documentos electrónicos con fines ilegales, como falsificar contratos, facturas o certificados.

- » **Firewall:** Dispositivo de seguridad en redes informáticas que monitorea y filtra el tráfico de datos entre redes, impidiendo accesos no autorizados.
- » **Firma digital:** Procedimiento de validación de un mensaje digital utilizando la clave privada de una persona, lo que garantiza la autenticidad y la integridad del mensaje.
- » **Grooming:** Acoso en línea a menores de edad con fines sexuales, mediante la creación de relaciones de confianza para manipular a la víctima.
- » **Ingeniería social:** Táctica utilizada por ciberdelincuentes para manipular a las personas y obtener acceso a sistemas, redes o información confidencial, basándose en la psicología y no en vulnerabilidades técnicas.
- » **Intrusión:** Acceso no autorizado a un sistema informático con el objetivo de obtener información o causar daño.
- » **Ley de Servicios de la Sociedad de la Información y Comercio Electrónico (LSSICE):** Norma que regula los servicios de la sociedad de la información, incluidos los relacionados con el comercio electrónico y la protección de datos en el entorno digital.
- » **Ley Orgánica de Protección de Datos Personales y Garantía de los Derechos Digitales (LOPDPGDD):** Legislación española que adapta el Reglamento General de Protección de Datos (RGPD) a la normativa nacional, garantizando la protección de los datos personales y los derechos digitales.
- » **Malware como servicio (MaaS):** Modelo de negocio en los que los ciberdelincuentes ofrecen malware y herramientas de ataque cibernético como un servicio a otros criminales, facilitando el acceso a software malicioso.
- » **Malware:** Software malicioso diseñado para dañar o robar información de dispositivos o sistemas informáticos.
- » **Mitigación de riesgos:** Estrategias y prácticas utilizadas para reducir la probabilidad o el impacto de una amenaza para la seguridad, protegiendo así los sistemas y datos informáticos.
- » **Pharming:** Técnica más avanzada de suplantación de identidad que redirige a los usuarios a sitios web falsos, incluso cuando escriben la dirección correcta.
- » **Phishing:** Técnica de ingeniería social en la que los ciberdelincuentes suplantan la identidad de entidades legítimas (como bancos) para robar información confidencial, como contraseñas o números de tarjeta.

- » **Pornografía infantil:** Producción, distribución o posesión de material pornográfico que involucra menores de edad, un delito grave tipificado en el Código Penal.
- » **Privacidad en Internet:** Derecho y práctica de proteger la información personal en línea, incluyendo la gestión de qué datos se comparten, con quién se comparten y cómo se protegen.
- » **Protección física de los sistemas informáticos:** Conjunto de medidas de seguridad destinadas a proteger el acceso físico a los sistemas informáticos, como el control de acceso a los equipos y el uso de dispositivos de seguridad como cerraduras o cámaras.
- » **Ransomware:** Tipo de malware que bloquea o cifra archivos en un sistema y exige un pago para liberarlos.
- » **Red de confianza:** Sistema en el que los miembros de una red confían entre sí para compartir información y recursos, generalmente mediante la implementación de mecanismos de autenticación y autorización.
- » **Redes de botnets:** Red de dispositivos infectados por malware, controlados remotamente por un atacante y utilizados para realizar ataques masivos, como ataques DDoS o envío de spam.
- » **Reglamento General de Protección de Datos (RGPD):** Reglamento de la Unión Europea que establece las normas para el tratamiento y la protección de los datos personales de los ciudadanos europeos.
- » **Responsabilidad penal del profesional informático:** Obligación legal de los técnicos y profesionales de la informática de cumplir con la ley, tanto en el ámbito laboral como en el personal. El desconocimiento de las leyes informáticas no exime de responsabilidad penal.
- » **Responsable del tratamiento:** Persona o entidad que decide cómo y por qué se tratan los datos personales de los individuos.
- » **Robo de identidad:** Acto de obtener y usar los datos personales de otra persona sin su consentimiento para cometer fraudes, suplantar su identidad o realizar transacciones ilícitas.
- » **Skimming:** Técnica de fraude en la que los delincuentes copian la información de la banda magnética de una tarjeta de crédito o débito sin el consentimiento del titular.

- » **Software espía (spyware):** Tipo de software malicioso que se instala en un sistema sin el conocimiento del usuario con el objetivo de monitorear sus actividades, robar información o controlar su dispositivo.
- » **Spoofing:** Suplantación de identidad en línea por medio de la falsificación de direcciones IP, correos electrónicos o sitios web, con el fin de engañar a las víctimas.
- » **Stalking:** Persecución o vigilancia obsesiva, generalmente a través de medios electrónicos, que afecta gravemente a la privacidad de la víctima.
- » **Suplantación de identidad digital:** Acto de asumir la identidad de otra persona en plataformas digitales para llevar a cabo fraudes, obtener acceso a cuentas o realizar actividades ilegales.
- » **Vulnerabilidad:** Debilidad o falla en un sistema informático, red o aplicación que puede ser explotada por un atacante para comprometer la seguridad de la información o los recursos.

Bibliografía

Constitución española (1978). Disponible en:

<https://www.boe.es/buscar/act.php?id=BOE-A-1978-31229>

Reglamento General de Protección de Datos (RGPD). Reglamento (UE) 2016/679 del Parlamento Europeo y del Consejo. Disponible en:

<https://eur-lex.europa.eu/legal-content/ES/TXT/?uri=celex%3A32016R0679>

Ley 34/2002 de Servicios de la Sociedad de la Información y de Comercio Electrónico (LSSICE). Disponible en: <https://www.boe.es/buscar/act.php?id=BOE-A-2002-13758>

Ley 59/2003 de Firma Electrónica. Disponible en:

<https://www.boe.es/buscar/doc.php?id=BOE-A-2003-23399>

Cano, J. (2020). *Delitos informáticos y ciberseguridad*. Tirant Lo Blanch.

Rebollo, M., y Fernández-Medina, E. (2018). *Seguridad en sistemas informáticos y redes*. Universidad de Castilla-La Mancha.

García, A. (2022). *Protección de datos y legislación TIC*. Editorial RA-MA.

Código Penal español (LO 10/1995 y sus reformas). BOE. Disponible en:

<https://www.boe.es/buscar/act.php?id=BOE-A-1995-25444>

Ley Orgánica 3/2018, de Protección de Datos Personales y Garantía de los Derechos Digitales (LOPDPGDD). BOE. Disponible en: <https://www.boe.es/eli/es/lo/2018/12/05/3>

UAX FP